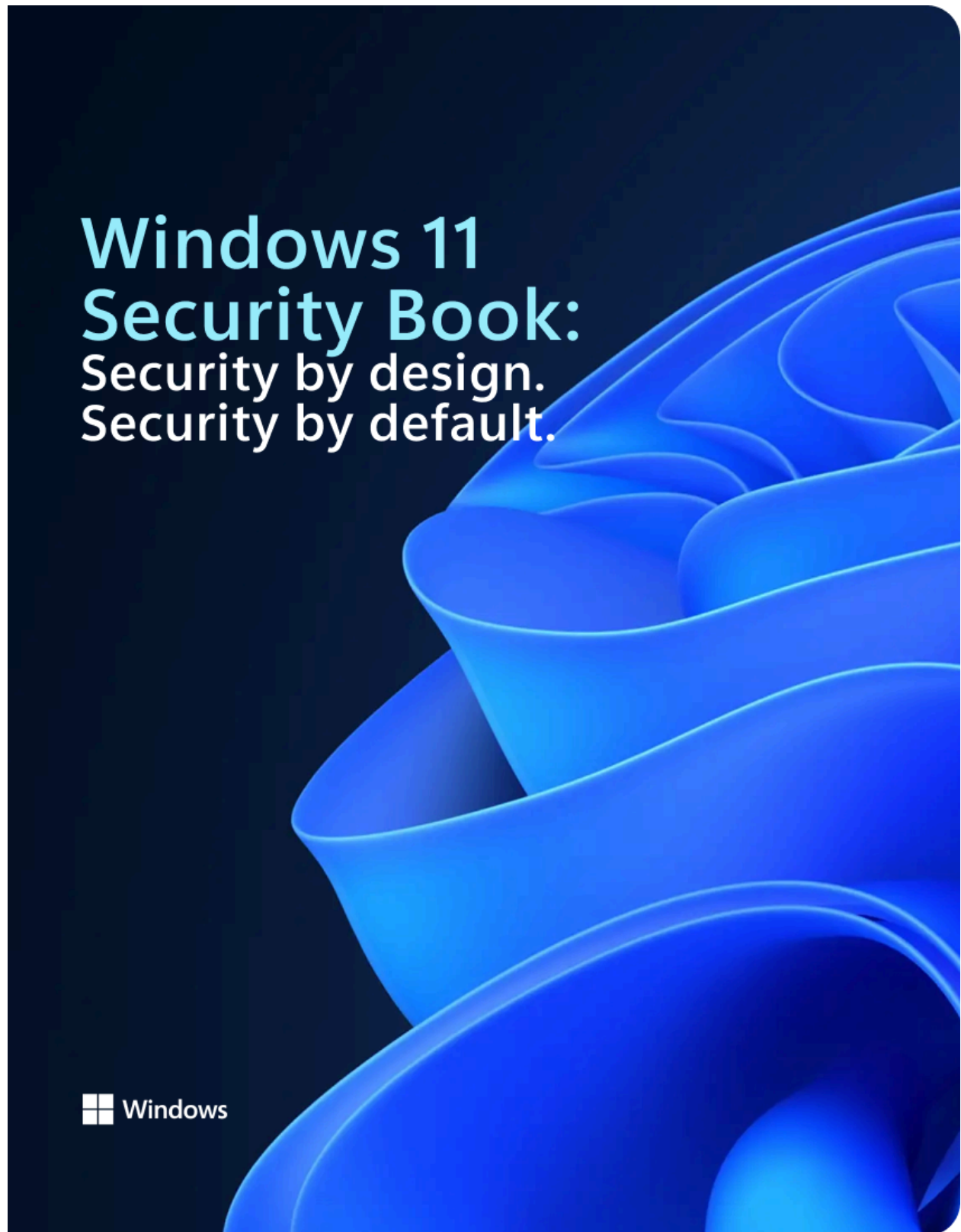


Windows 11 Security Book

Article • 11/19/2024 • Applies to: [Windows 11](#)



Introduction

Today's organizations face a world of accelerated change, from marketplace fluctuation and sociopolitical events to the rapid adoption of new AI technologies. However, as organizations and industries innovate, so do increasingly sophisticated cybercriminals. Research shows that employees, including their devices, services, and identities, are at the center of attacks on businesses of all sizes. Some leading threats include identity attacks, ransomware, targeted phishing attempts, and business email compromise^[1].

To address the ever-growing and changing threat landscape, we announced the [Secure Future Initiative \(SFI\)](#) in November 2023. The SFI endeavors to advance cybersecurity protection across all our company and products.

Microsoft is committed to putting security above all else, with products and services that are secure by design and secure by default. We synthesize more than 65 trillion signals daily to understand digital threats and criminal cyberactivity^[1]. Through the SFI initiative, we've dedicated the equivalent of 34,000 full-time engineers to the highest priority security tasks. We continuously apply what we learn from incidents to improve our security and privacy models, security architecture, and technical controls.

Security by design. Security by default.

Working together with a shared focus is key to improving global security, from individuals and organizations to governments and industries. The world is moving toward a [secure by design and secure by default](#) approach, where technology producers are tasked with incorporating security during the initial design phase, and offering products that deliver protection right out of the box. As part of our commitment to making the world a safer place, we build security into every innovation. Windows 11 is secure by design and secure by default, with layers of defense enabled on day one to enhance your protection without the need to first configure settings. This secure-by-design approach spans the Windows edition range including Pro, Enterprise, IoT Enterprise, and Education editions. Copilot+ PCs are the fastest, most intelligent Windows devices ever, and they're also the most secure. These groundbreaking AI PCs come with secured-core PC protection and the latest safeguards like Microsoft Pluton and Windows Enhanced Sign-in Security enabled by default.

Except for Windows IoT Long-Term Servicing Channel (LTSC) editions, support for Windows 10 is ending soon on October 14, 2025. Upgrading or replacing outdated devices before Windows 10 support ends is a critical priority for building a strong security posture. Discover why organizations of all sizes, including 90% of Fortune 500 companies, are relying on Windows 11.

Security priorities and benefits

Windows 11 enables you to focus on your work, not your security settings. Out-of-the-box features such as credential safeguards, malware shields, and application protection led to a reported 62% drop in security incidents, including a 3.0x reduction in firmware attacks^[2].

In Windows 11, hardware and software work together to shrink the attack surface, protect system integrity, and shield valuable data. New and enhanced features are designed for security by default. For example, Win32 apps in isolation^[3], token protection^[3], passkeys, and Microsoft Intune Endpoint Privilege Management^[4] are some of the latest capabilities that help protect organizations and individual users against attack. Windows Hello and Windows Hello for Business work with hardware-based features like Trusted Platform Module (TPM) 2.0, biometric scanners, and Windows presence sensing to enable easier, secure sign-on and protection of your data and credentials.

Existing security features are also continuously enhanced across Windows 11. For example, BitLocker encryption has been optimized for additional security and performance, and is available on more devices.

Identity protection

Attackers are increasingly targeting employees and their devices, so organizations need stronger security against increasingly sophisticated cyberthreats. Windows 11 provides proactive protection against credential theft. Windows Hello and TPM 2.0 work together to shield identities, and features like passkeys and secure biometric sign-in virtually eliminate the risk of lost or stolen passwords^[5]. Enhanced phishing protection also increases safety; in fact, businesses reported 2.9x fewer instances of identity theft with the hardware-backed protection in Windows 11^[2].

Application safeguards

Help keep business data secure and employees productive with robust safeguards and control for applications. Windows 11 has multiple layers of security that shield critical data and defend code integrity. Application protection, privacy controls, and least-privilege principles enable developers to build in security by design. This integrated defense helps protect against breaches and malware, assists in keeping data private, and gives IT administrators the controls they need. As a result, organizations and regulators can be confident that critical data is protected.

With Trusted Signing, developers can effortlessly sign their applications. This process ensures the authenticity and integrity of the applications while enhancing security

features to prevent and mitigate the impacts of malware on Windows.

Device health and access control

Increase protection and efficiency with Windows 11 and chip-to-cloud security. Microsoft provides the tools needed to attest that the devices connecting to your network, or accessing your data and resources, are trustworthy. You can enforce security policies and conditional access with cloud-based device management solutions such as Microsoft Intune, Microsoft Entra ID, and a comprehensive security baseline. Security by default not only enables people to work securely anywhere, but it also simplifies IT. A streamlined, chip-to-cloud security solution based on Windows 11 improves productivity for IT and security teams by a reported 25%^[6].

Chip-to-cloud security

In Windows 11, hardware and software work together to protect sensitive data, from the core of the device all the way to the cloud. Comprehensive protection helps keep organizations secure, no matter where people work. The following diagram shows the layers of protection in Windows 11, while each chapter provides a layer-by-layer deep dive into features.



[Learn more](#)

- [Windows security features licensing and edition requirements](#)

Hardware security

Article • 11/19/2024 • Applies to: [Windows 11](#)



Today's ever-evolving threats require strong alignment between hardware and software to keep users, data, and devices protected. The operating system and software alone can't defend against the wide range of tools used by cybercriminals to steal credentials, take data, and implant malware.

In partnership with our silicon and device manufacturing partners, Windows 11 devices shield software, hardware, and firmware with features like Trusted Platform Module (TPM) 2.0, Microsoft Pluton, and Virtualization-based security (VBS). Windows 11 devices provide hardware-backed protection by default to significantly improve security while maintaining the performance that users expect.



Hardware root-of-trust

Article • 11/19/2024 • Applies to: [Windows 11](#)



Trusted Platform Module (TPM)

Trusted Platform Module (TPM) technology is designed to provide hardware-based, security-related functions. TPMs provide security and privacy benefits for system hardware, platform owners, and users. Windows Hello, BitLocker, System Guard, and other Windows features rely on the TPM for capabilities such as key generation, secure storage, encryption, boot integrity measurements, and attestation. These capabilities in turn help organizations strengthen the protection of their identities and data. The 2.0 version of TPM includes support for newer algorithms, which provides improvements like support for stronger cryptography. To upgrade to Windows 11, existing Windows 10 devices must meet minimum system requirements for CPU, RAM, storage, firmware, TPM, and more. All new Windows 11 devices come with TPM 2.0 built-in. With Windows 11, both new and upgraded devices must have TPM 2.0. The requirement strengthens the security posture across all Windows 11 devices and helps ensure that these devices can benefit from future security capabilities that depend on a hardware root-of-trust.

Learn more

- [Windows 11 TPM specifications](#) 
- [Enable TPM 2.0 on your PC](#) 
- [Trusted Platform Module Technology Overview](#)

Microsoft Pluton security processor

The Microsoft Pluton security processor is the result of Microsoft's close partnership with silicon partners. Pluton enhances the protection of Windows 11 devices with a hardware security processor that provides extra protection for cryptographic keys and other secrets. Pluton is designed to reduce the attack surface by integrating the security chip directly into the processor. It can be used as a TPM 2.0 or as a standalone security processor. When a security processor is located on a separate, discrete chip on the motherboard, the communication path between the hardware root-of-trust and the CPU can be vulnerable to physical attack. Embedding Pluton into the CPU makes it harder to exploit the communication path.

Pluton supports the TPM 2.0 industry standard, allowing customers to immediately benefit from enhanced security for Windows features that rely on TPMs, including BitLocker, Windows Hello, and System Guard. Pluton can also support other security functionality beyond what is possible with the TPM 2.0 specification. This extensibility allows for more Pluton firmware and OS features to be delivered over time via Windows Update.

As with other TPMs, credentials, encryption keys, and other sensitive information can't be easily extracted from Pluton even if an attacker installed malware or has physical possession of the PC. Storing sensitive data like encryption keys securely within the Pluton processor, which is isolated from the rest of the system, helps ensure that attackers can't access sensitive data - even if attackers use emerging techniques like speculative execution.

Pluton also solves the major security challenge of keeping its own security processor firmware up to date across the entire PC ecosystem. Today customers receive security firmware updates from different sources, which might make it difficult to get alerts about security updates, and keeping systems in a vulnerable state. Pluton provides a flexible, updateable platform for its firmware that implements end-to-end security functionality authored, maintained, and updated by Microsoft. Pluton is integrated with the Windows Update service, benefiting from over a decade of operational experience in reliably delivering updates across over a billion endpoint systems. Microsoft Pluton is available with select new Windows PCs.

Pluton aims to ensure long-term security resilience. With the rising threat landscape influenced by artificial intelligence, memory safety will become ever more critical. To meet these demands, in addition to facilitating reliable updates to security processor firmware, we chose the open-source Tock system as the Rust-based foundation to develop the Pluton security processor firmware and actively contribute back to the Tock community. This collaboration with an open community ensures rigorous security scrutiny, and using Rust mitigates memory safety threats.

Ultimately, Pluton establishes the security backbone for Copilot + PC, thanks to tight partnerships with our silicon collaborators and OEMs. The Qualcomm Snapdragon X, AMD Ryzen AI, and Intel Core Ultra 200V mobile processors (codenamed Lunar Lake) processor platforms all incorporate Pluton as their security subsystem .

Learn more

- [Microsoft Pluton processor - The security chip designed for the future of Windows PCs](#) 
- [Microsoft Pluton security processor](#)

Silicon assisted security

Article • 11/19/2024 • Applies to: [Windows 11](#)



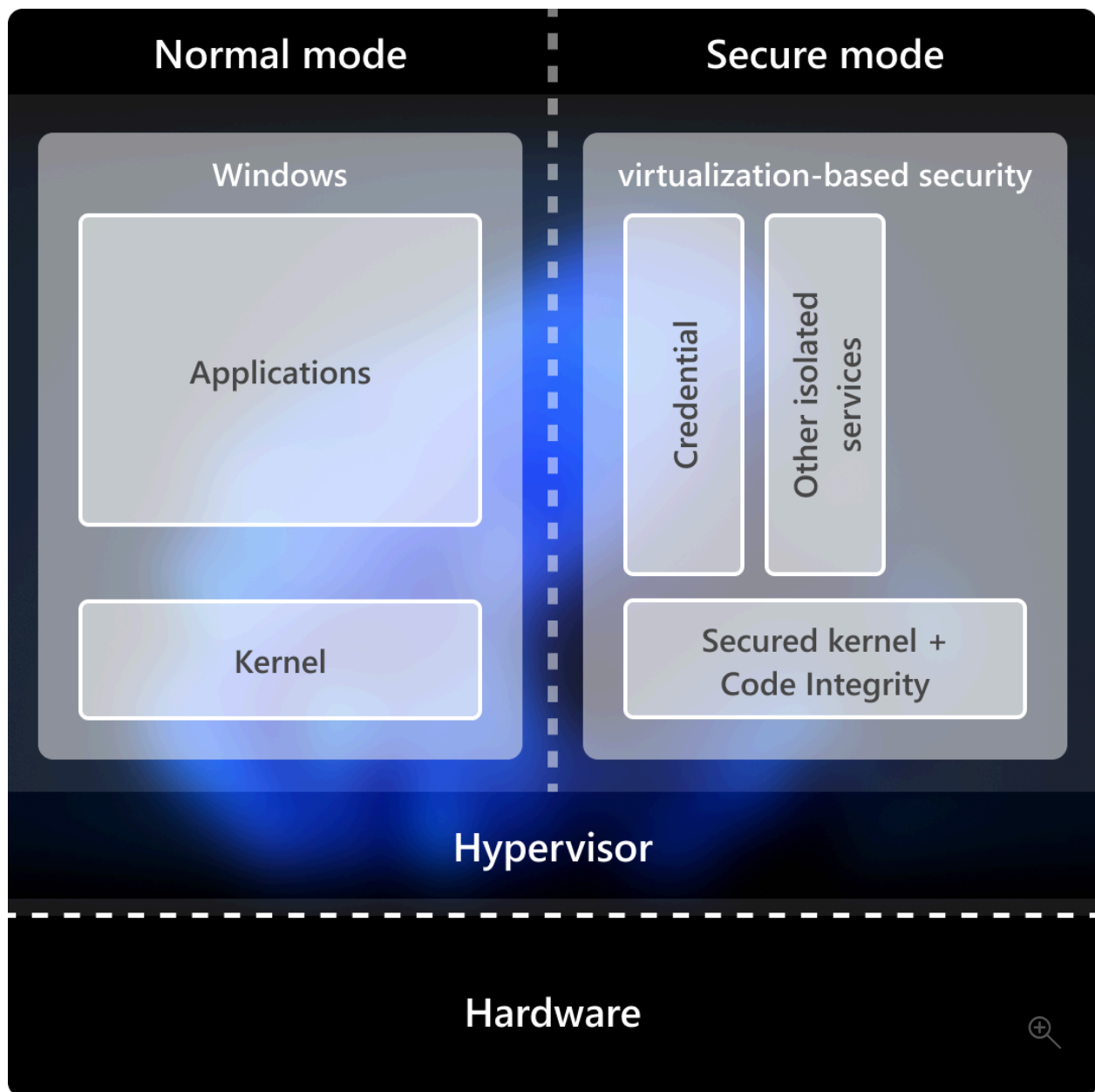
In addition to a modern hardware root-of-trust, there are multiple capabilities in the latest chips that harden the operating system against threats. These capabilities protect the boot process, safeguard the integrity of memory, isolate security-sensitive compute logic, and more.

Secured kernel

To secure the kernel, we have two key features: Virtualization-based security (VBS) and hypervisor-protected code integrity (HVCI). All Windows 11 devices support HVCI and come with VBS and HVCI protection turned on by default on most/all devices.

Virtualization-based security (VBS)

Virtualization-based security (VBS), also known as core isolation, is a critical building block in a secure system. VBS uses hardware virtualization features to host a secure kernel separated from the operating system. This means that even if the operating system is compromised, the secure kernel is still protected. The isolated VBS environment protects processes, such as security solutions and credential managers, from other processes running in memory. Even if malware gains access to the main OS kernel, the hypervisor and virtualization hardware help prevent the malware from executing unauthorized code or accessing platform secrets in the VBS environment. VBS implements virtual trust level 1 (VTL1), which has higher privilege than the virtual trust level 0 (VTL0) implemented in the main kernel.



Since more privileged virtual trust levels (VTLs) can enforce their own memory protections, higher VTLs can effectively protect areas of memory from lower VTLs. In practice, this allows a lower VTL to protect isolated memory regions by securing them with a higher VTL. For example, VTL0 could store a secret in VTL1, at which point only VTL1 could access it. Even if VTL0 is compromised, the secret would be safe.

i Learn more

- [Virtualization-based security \(VBS\)](#)

Hypervisor-protected code integrity (HVCI)

Hypervisor-protected code integrity (HVCI), also called memory integrity, uses VBS to run Kernel Mode Code Integrity (KMCI) inside the secure VBS environment instead of the main Windows kernel. This helps prevent attacks that attempt to modify kernel-

mode code for things like drivers. The KMCI checks that all kernel code is properly signed and hasn't been tampered with before it's allowed to run. HVCI ensures that only validated code can be executed in kernel mode. The hypervisor uses processor virtualization extensions to enforce memory protections that prevent kernel-mode software from executing code that hasn't been first validated by the code integrity subsystem. HVCI protects against common attacks like WannaCry that rely on the ability to inject malicious code into the kernel. HVCI can prevent injection of malicious kernel-mode code even when drivers and other kernel-mode software have bugs.

With new installs of Windows 11, OS support for VBS and HVCI is turned on by default for all devices that meet prerequisites.

Learn more

- [Enable virtualization-based protection of code integrity](#)

Hypervisor-enforced Paging Translation (HVPT)

Hypervisor-enforced Paging Translation (HVPT) is a security enhancement to enforce the integrity of guest virtual address to guest physical address translations. HVPT helps protect critical system data from write-what-where attacks where the attacker can write an arbitrary value to an arbitrary location often as the result of a buffer overflow. HVPT helps to protect page tables that configure critical system data structures.

Hardware-enforced stack protection

Hardware-enforced stack protection integrates software and hardware for a modern defense against cyberthreats like memory corruption and zero-day exploits. Based on Control-flow Enforcement Technology (CET) from Intel and AMD Shadow Stacks, hardware-enforced stack protection is designed to protect against exploit techniques that try to hijack return addresses on the stack.

Application code includes a program processing stack that hackers seek to corrupt or disrupt in a type of attack called *stack smashing*. When defenses like executable space protection began thwarting such attacks, hackers turned to new methods like return-oriented programming. Return-oriented programming, a form of advanced stack smashing, can bypass defenses, hijack the data stack, and ultimately force a device to perform harmful operations. To guard against these control-flow hijacking attacks, the Windows kernel creates a separate *shadow stack* for return addresses. Windows 11 extends stack protection capabilities to provide both user mode and kernel mode support.

Learn more

- [Understanding Hardware-enforced Stack Protection](#) 
- [Developer Guidance for hardware-enforced stack protection](#) 

Kernel direct memory access (DMA) protection

Windows 11 protects against physical threats such as drive-by direct memory access (DMA) attacks. Peripheral Component Interconnect Express (PCIe) hot-pluggable devices, including Thunderbolt, USB4, and CExpress, enable users to connect a wide variety of external peripherals to their PCs with the same plug-and-play convenience as USB. These devices encompass graphics cards and other PCI components. Since PCI hot-plug ports are external and easily accessible, PCs are susceptible to drive-by DMA attacks. Memory access protection (also known as Kernel DMA Protection) protects against these attacks by preventing external peripherals from gaining unauthorized access to memory. Drive-by DMA attacks typically happen quickly while the system owner isn't present. The attacks are performed using simple to moderate attacking tools created with affordable, off-the-shelf hardware and software that don't require the disassembly of the PC. For example, a PC owner might leave a device for a quick coffee break. Meanwhile, an attacker plugs an external tool into a port to steal information or inject code that gives the attacker remote control over the PCs, including the ability to bypass the lock screen. With memory access protection built in and enabled, Windows 11 is protected against physical attack wherever people work.

Learn more

- [Kernel direct memory access \(DMA\) protection](#)

Secured-core PC and Edge Secured-Core

The March 2021 Security Signals report found that more than 80% of enterprises have experienced at least one firmware attack in the past two years. For customers in data-sensitive industries like financial services, government, and healthcare, Microsoft has worked with OEM partners to offer a special category of devices called Secured-core PCs (SCPCs), and an equivalent category of embedded IoT devices called Edge Secured-Core (ESc). The devices ship with more security measures enabled at the firmware layer, or device core, that underpins Windows.

Secured-core PCs and edge devices help prevent malware attacks and minimize firmware vulnerabilities by launching into a clean and trusted state at startup with a hardware-enforced root-of-trust. Virtualization-based security comes enabled by

default. Built-in hypervisor-protected code integrity (HVCI) shield system memory, ensuring that all kernel executable code is signed only by known and approved authorities. Secured-core PCs and edge devices also protect against physical threats such as drive-by direct memory access (DMA) attacks with kernel DMA protection.

Secured-core PCs and edge devices provide multiple layers of robust protection against hardware and firmware attacks. Sophisticated malware attacks commonly attempt to install *bootkits* or *rootkits* on the system to evade detection and achieve persistence. This malicious software may run at the firmware level prior to Windows being loaded or during the Windows boot process itself, enabling the system to start with the highest level of privilege. Because critical subsystems in Windows use Virtualization-based security, protecting the hypervisor becomes increasingly important. To ensure that no unauthorized firmware or software can start before the Windows bootloader, Windows PCs rely on the Unified Extensible Firmware Interface (UEFI) Secure Boot standard, a baseline security feature of all Windows 11 PCs. Secure Boot helps ensure that only authorized firmware and software with trusted digital signatures can execute. In addition, measurements of all boot components are securely stored in the TPM to help establish a nonrepudiable audit log of the boot called the Static Root of Trust for Measurement (SRTM).

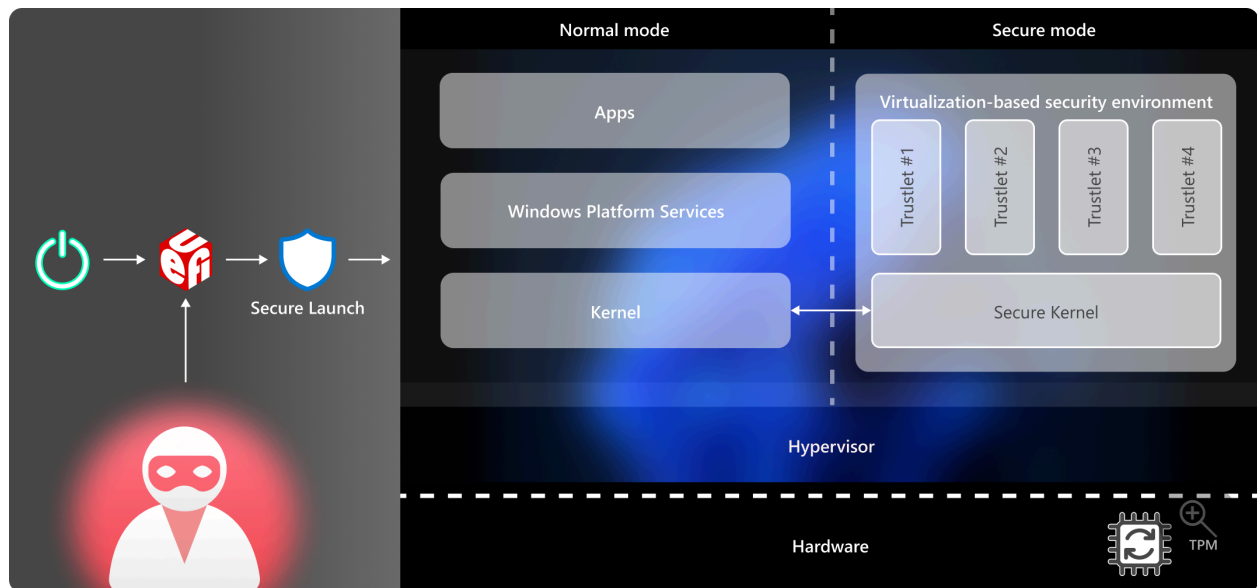
Thousands of OEM vendors produce numerous device models with diverse UEFI firmware components, which in turn creates an incredibly large number of SRTM signatures and measurements at bootup. Because these signatures and measurements are inherently trusted by Secure Boot, it can be challenging to constrain trust to only what is needed to boot on any specific device. Traditionally, blocklists and allowlists were the two main techniques used to constrain trust, and they continue to expand if devices rely only on SRTM measurements.

Dynamic Root of Trust for Measurement (DRTM)

In secured-core PCs and edge devices, System Guard Secure Launch protects bootup with a technology known as the *Dynamic Root of Trust for Measurement (DRTM)*. With DRTM, the system initially follows the normal UEFI Secure Boot process. However, before launching, the system enters a hardware-controlled trusted state that forces the CPU down a hardware-secured code path. If a malware rootkit or bootkit bypasses UEFI Secure Boot and resides in memory, DRTM prevents it from accessing secrets and critical code protected by the Virtualization-based security environment. Firmware Attack Surface Reduction (FASR) technology can be used instead of DRTM on supported devices, such as Microsoft Surface.

System Management Mode (SMM) isolation is an execution mode in x86-based processors that runs at a higher effective privilege than the hypervisor. SMM

complements the protections provided by DRTM by helping to reduce the attack surface. Relying on capabilities provided by silicon providers like Intel and AMD, SMM isolation enforces policies that implement restrictions such as preventing SMM code from accessing OS memory. The SMM isolation policy is included as part of the DRTM measurements that can be sent to a verifier like Microsoft Azure Remote Attestation.



[Learn more](#)

- [System Guard Secure Launch](#)
- [Firmware Attack Surface Reduction](#)
- [Windows 11 secured-core PCs](#)
- [Edge Secured-Core](#)

Configuration lock

In many organizations, IT administrators enforce policies on their corporate devices to protect the OS and keep devices in a compliant state by preventing users from changing configurations and creating configuration drift. Configuration drift occurs when users with local admin rights change settings and put the device out of sync with security policies. Devices in a noncompliant state can be vulnerable until the next sync, when configuration is reset with the device management solution.

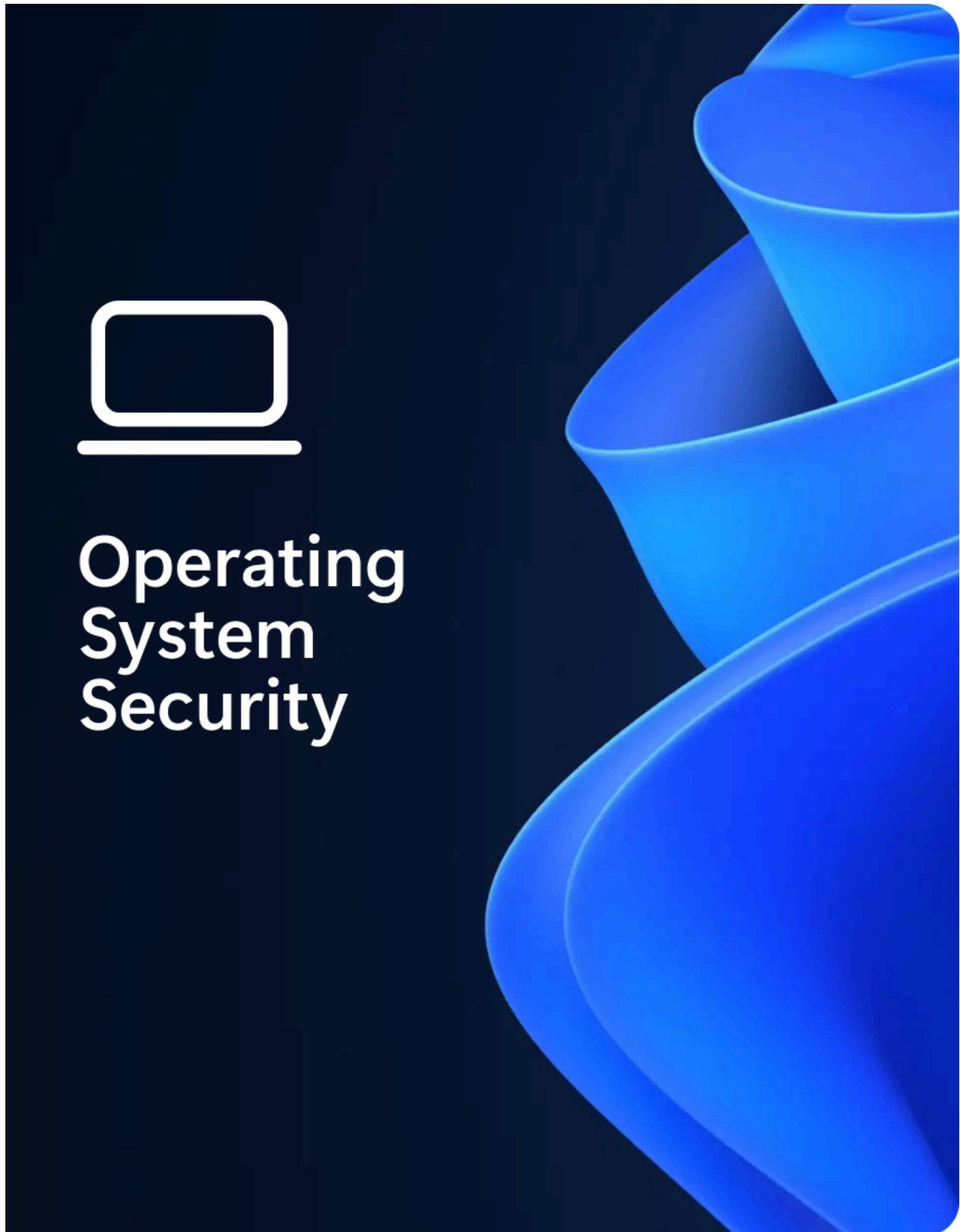
Configuration lock is a secured-core PC and edge device feature that prevents users from making unwanted changes to security settings. With configuration lock, Windows monitors supported registry keys and reverts to the IT-desired state in seconds after detecting a drift.

[Learn more](#)

- [Secured-core PC configuration lock](#)

Operating System security

Article • 11/19/2024 • Applies to: [Windows 11](#)



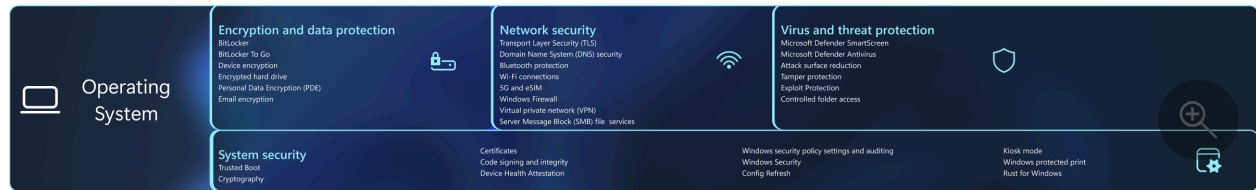
Operating systems face an onslaught of security threats, from malware and exploits to unauthorized access and privilege escalation. Windows 11 is the most secure Windows yet, with strong operating system safeguards to help keep devices, identities, and data safe.

Defenses include a trusted boot process, layers of encryption, network security, and virus and threat protection. These comprehensive security features ensure that Windows 11 provides robust protection against modern cyber threats.



System security

Article • 11/19/2024 • Applies to: [Windows 11](#)



Trusted Boot (Secure Boot + Measured Boot)

Windows 11 requires all PCs to use Unified Extensible Firmware Interface (UEFI)'s Secure Boot feature. When a Windows 11 device starts, Secure Boot and Trusted Boot work together to prevent malware and corrupted components from loading. Secure Boot provides initial protection, then Trusted Boot picks up the process.

Secure Boot makes a safe and trusted path from the Unified Extensible Firmware Interface (UEFI) through the Windows kernel's Trusted Boot sequence. Malware attacks on the Windows boot sequence are blocked by the signature-enforcement handshakes throughout the boot sequence between the UEFI, bootloader, kernel, and application environments.

To mitigate the risk of firmware rootkits, the PC verifies the digital signature of the firmware at the start of the boot process. Secure Boot then checks the digital signature of the OS bootloader and all code that runs before the operating system starts, ensuring that the signature and code are uncompromised and trusted according to the Secure Boot policy.

Trusted Boot picks up the process that begins with Secure Boot. The Windows bootloader verifies the digital signature of the Windows kernel before loading it. The Windows kernel, in turn, verifies every other component of the Windows startup process, including boot drivers, startup files, and any anti-malware product's early-launch anti-malware (ELAM) driver. If any of these files have been tampered with, the bootloader detects the problem and refuses to load the corrupted component. Often, Windows can automatically repair the corrupted component, restoring the integrity of Windows and allowing the PC to start normally.

Learn more

- [Secure the Windows boot process](#)
- [Secure Boot and Trusted Boot](#)

Cryptography

Cryptography is designed to protect user and system data. The cryptography stack in Windows 11 extends from the chip to the cloud, enabling Windows, applications, and services to protect system and user secrets. For example, data can be encrypted so that only a specific reader with a unique key can read it. As a basis for data security, cryptography helps prevent anyone except the intended recipient from reading data, performs integrity checks to ensure data is free of tampering, and authenticates identity to ensure that communication is secure. Windows 11 cryptography is certified to meet the Federal Information Processing Standard (FIPS) 140. FIPS 140 certification ensures that US government-approved algorithms are correctly implemented.

Learn more

- FIPS 140 validation

Windows cryptographic modules provide low-level primitives such as:

- Random number generators (RNG)
- Support for AES 128/256 with XTS, ECB, CBC, CFB, CCM, and GCM modes of operation; RSA and DSA 2048, 3072, and 4,096 key sizes; ECDSA over curves P-256, P-384, P-521
- Hashing (support for SHA1, SHA-256, SHA-384, and SHA-512)
- Signing and verification (padding support for OAEP, PSS, and PKCS1)
- Key agreement and key derivation (support for ECDH over NIST-standard prime curves P-256, P-384, P-521 and HKDF)

Application developers can use these cryptographic modules to perform low-level cryptographic operations (Bcrypt), key storage operations (NCrypt), protect static data (DPAPI), and securely share secrets (DPAPI-NG).

Learn more

- Cryptography and certificate management

Developers can access the modules on Windows through the Cryptography Next Generation API (CNG), which is powered by Microsoft's open-source cryptographic library, SymCrypt. SymCrypt supports complete transparency through its open-source code. In addition, SymCrypt offers performance optimization for cryptographic operations by taking advantage of assembly and hardware acceleration when available.

SymCrypt is part of Microsoft's commitment to transparency, which includes the global Microsoft Government Security Program that aims to provide the confidential security information and resources people need to trust Microsoft's products and services. The

program offers controlled access to source code, threat and vulnerability information exchange, opportunities to engage with technical content about Microsoft's products and services, and access to five globally distributed Transparency Centers.

Certificates

To help safeguard and authenticate information, Windows provides comprehensive support for certificates and certificate management. The built-in certificate management command-line utility (certmgr.exe) or Microsoft Management Console (MMC) snap-in (certmgr.msc) can be used to view and manage certificates, certificate trust lists (CTLs), and certificate revocation lists (CRLs). Whenever a certificate is used in Windows, we validate that the leaf certificate and all the certificates in its chain of trust haven't been revoked or compromised. The trusted root and intermediate certificates and publicly revoked certificates on the machine are used as a reference for Public Key Infrastructure (PKI) trust and are updated monthly by the Microsoft Trusted Root program. If a trusted certificate or root is revoked, all global devices are updated, meaning users can trust that Windows will automatically protect against vulnerabilities in public key infrastructure. For cloud and enterprise deployments, Windows also offers users the ability to autoenroll and renew certificates in Active Directory with group policy to reduce the risk of potential outages due to certificate expiration or misconfiguration.

Code signing and integrity

To ensure that Windows files haven't been tampered with, the Windows Code Integrity process verifies the signature of each file in Windows. Code signing is core to establishing the integrity of firmware, drivers, and software across the Windows platform. Code signing creates a digital signature by encrypting the hash of the file with the private key portion of a code-signing certificate and embedding the signature into the file. The Windows code integrity process verifies the signed file by decrypting the signature to check the integrity of the file and confirm that it is from a reputable publisher, ensuring that the file hasn't been tampered with.

The digital signature is evaluated across the Windows environment on Windows boot code, Windows kernel code, and Windows user mode applications. Secure Boot and Code Integrity verify the signature on bootloaders, Option ROMs, and other boot components to ensure that it's trusted and from a reputable publisher. For drivers not published by Microsoft, Kernel Code Integrity verifies the signature on kernel drivers and requires that drivers be signed by Windows or certified by the [Windows Hardware Compatibility Program \(WHCP\)](#). This program ensures that third-party drivers are

compatible with various hardware and Windows and that the drivers are from vetted driver developers.

Device Health Attestation

The Windows Device Health Attestation process supports a Zero Trust paradigm that shifts the focus from static, network-based perimeters to users, assets, and resources. The attestation process confirms the device, firmware, and boot process are in a good state and haven't been tampered with before they can access corporate resources. These determinations are made with data stored in the TPM, which provides a secure root-of-trust. The information is sent to an attestation service such as Azure Attestation to verify that the device is in a trusted state. Then a cloud-native device management solution like Microsoft Intune^[4] reviews device health and connects this information with Microsoft Entra ID^[4] for conditional access.

Windows includes many security features to help protect users from malware and attacks. However, security components are trustworthy only if the platform boots as expected and isn't tampered with. As noted above, Windows relies on Unified Extensible Firmware Interface (UEFI) Secure Boot, ELAM, DRTM, Trusted Boot, and other low-level hardware and firmware security features to protect your PC from attacks. From the moment you power on your PC until your anti-malware starts, Windows is backed with the appropriate hardware configurations that help keep you safe. Measured Boot, implemented by bootloaders and BIOS, verifies and cryptographically records each step of the boot in a chained manner. These events are bound to the TPM, that functions as a hardware root-of-trust. Remote attestation is the mechanism by which these events are read and verified by a service to provide a verifiable, unbiased, and tamper-resilient report. Remote attestation is the trusted auditor of your system's boot, allowing reliant parties to bind trust to the device and its security.

A summary of the steps involved in attestation and Zero-Trust on a Windows device are as follows:

- During each step of the boot process - such as a file load, update of special variables, and more - information such as file hashes and signature(s) are measured in the TPM Platform Configuration Register (PCRs). The measurements are bound by a Trusted Computing Group specification that dictates which events can be recorded and the format of each event. The data provides important information about device security from the moment it powers on
- Once Windows has booted, the attestor (or verifier) requests the TPM get the measurements stored in its PCRs alongside the Measured Boot log. Together, these form the attestation evidence that's sent to the Azure Attestation service

- The TPM is verified by using the keys or cryptographic material available on the chipset with an Azure Certificate Service
- The above information is sent to the Azure Attestation Service to verify that the device is in a trusted state.

i Learn more

- [Control the health of Windows devices](#)

Windows security policy settings and auditing

Security policy settings are a critical part of your overall security strategy. Windows provides a robust set of security setting policies that IT administrators can use to help protect Windows devices and other resources in your organization. Security policies settings are rules you can configure on a device, or multiple devices, to control:

- User authentication to a network or device
- Resources that users are permitted to access
- Whether to record a user or group's actions in the event log
- Membership in a group

Security auditing is one of the most powerful tools that you can use to maintain the integrity of your network and assets. Auditing can help identify attacks, network vulnerabilities, and attacks against high-value targets. You can specify categories of security-related events to create an audit policy tailored to the needs of your organization using configuration service providers (CSP) or group policies.

All auditing categories are disabled when Windows is first installed. Before enabling them, follow these steps to create an effective security auditing policy:

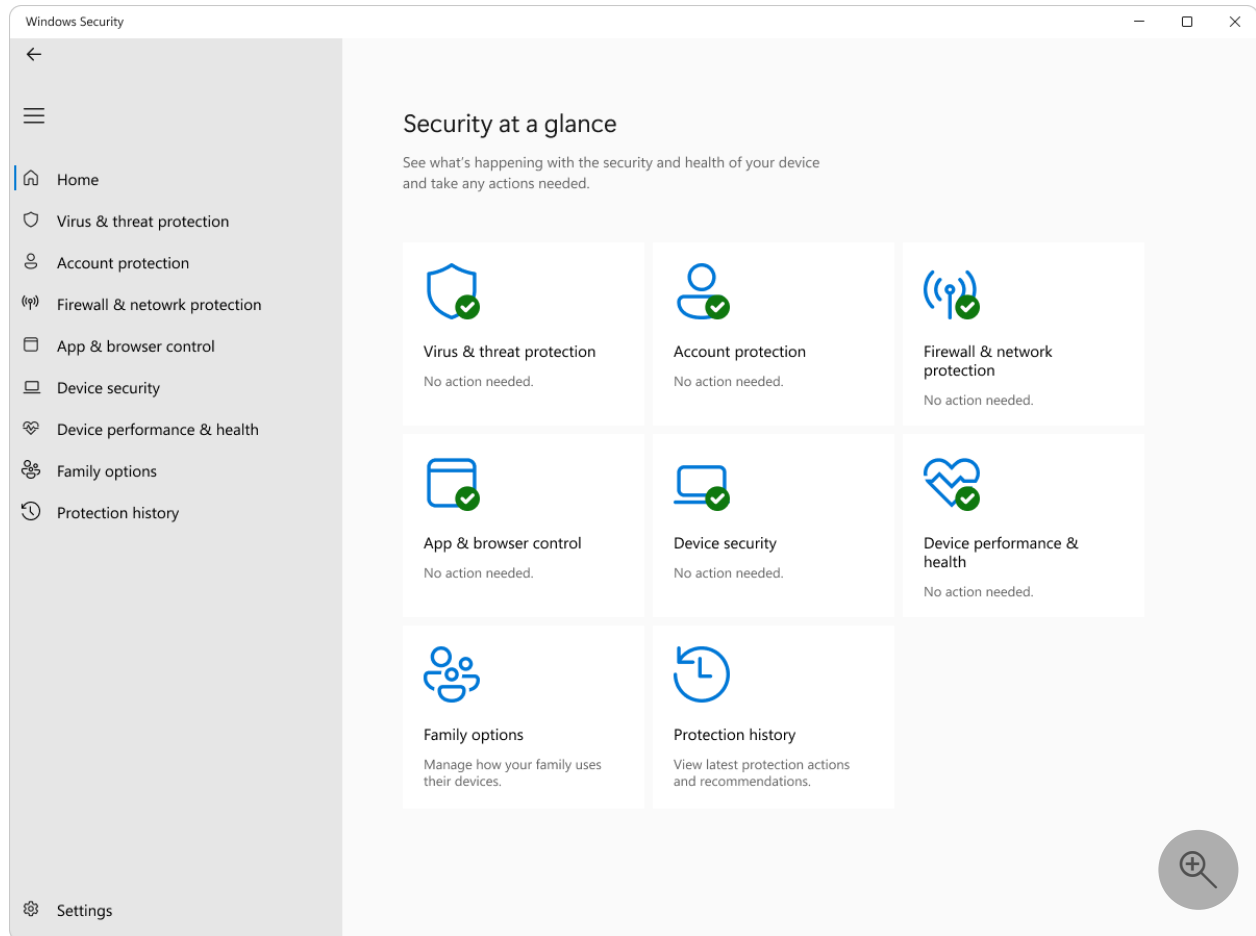
1. Identify your most critical resources and activities.
2. Identify the audit settings you need to track them.
3. Assess the advantages and potential costs associated with each resource or setting.
4. Test these settings to validate your choices.
5. Develop plans for deploying and managing your audit policy.

i Learn more

- [Security policy settings](#)
- [Security auditing](#)

Windows Security

Visibility and awareness of device security and health are key to any action taken. The Windows Security app provides an at-a-glance view of the security status and health of your device. These insights help you identify issues and act to make sure you're protected. You can quickly see the status of your virus and threat protection, firewall and network security, device security controls, and more.



Learn more

- [Stay protected with Windows Security](#) 
- [Windows Security](#)

Config Refresh

With traditional group policy, policy settings are refreshed on a PC when a user signs in and every 90 minutes by default. Administrators can adjust that timing to be shorter to ensure that the policy settings are compliant with the management settings set by IT.

By contrast, with a device management solution like Microsoft Intune^[4], policies are refreshed when a user signs in and then at eight-hours interval by default. But policy

settings are migrated from GPO to a device management solution, one remaining gap is the longer period between the reapplication of a changed policy.

Config Refresh allows settings in the Policy configuration service provider (CSP) that drift due to misconfiguration, registry edits, or malicious software on a PC to be reset to the value the administrator intended every 90 minutes by default. It's configurable to refresh every 30 minutes if desired. The Policy CSP covers hundreds of settings that were traditionally set with group policy and are now set through Mobile Device Management (MDM) protocols.

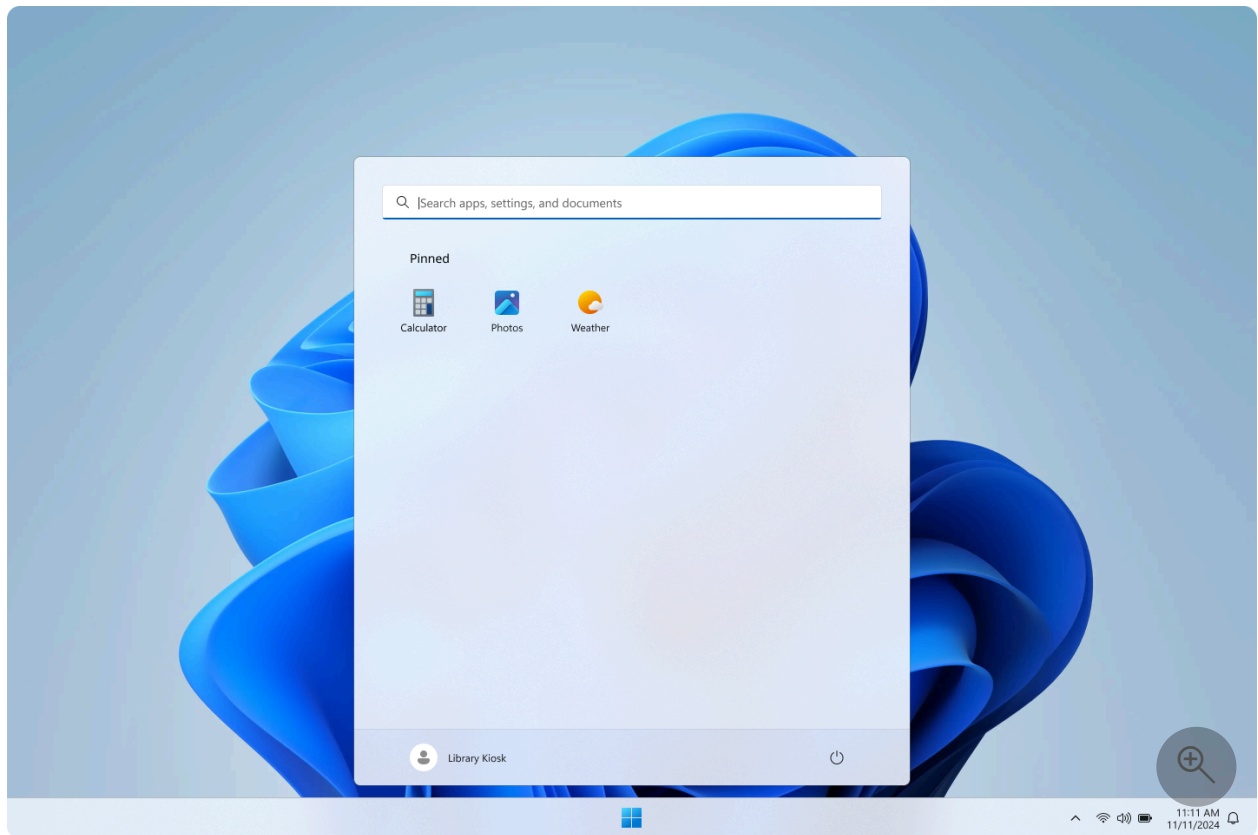
Config Refresh can also be paused for a configurable period of time, after which it will be reenabled. This is to support scenarios where a helpdesk technician might need to reconfigure a device for troubleshooting purposes. It can also be resumed at any time by an administrator.

Learn more

- [Config Refresh](#) 

Kiosk mode

Windows allows you to restrict functionality to specific applications using built-in features, making it ideal for public-facing or shared devices like kiosks. You can set up Windows as a kiosk either locally on the device, or through a cloud-based device management solution like Microsoft Intune^[7]. Kiosk mode can be configured to run a single app, multiple apps, or a full-screen web browser. You can also configure the device to automatically sign in and launch the designated kiosk app at startup.



Learn more

- [Windows kiosks and restricted user experiences](#)

Windows protected print

Windows protected print is built to provide a more modern and secure print system that maximizes compatibility and puts users first. It simplifies the printing experience by allowing devices to exclusively print using the Windows modern print stack.

The benefits of Windows protected print include:

- Increased PC security
- Simplified and consistent printing experience, regardless of PC architecture
- Removes the need to manage print drivers

Windows protected print is designed to work with Mopria certified printers only. Many existing printers are already compatible.

Learn more

- [Windows protected print](#)
- [New, modern, and secure print experience from Windows](#) 



Rust for Windows

Rust is a modern programming language known for its focus on safety, performance, and concurrency. It was designed to prevent common programming errors such as null pointer dereferencing and buffer overflows, which can lead to security vulnerabilities and crashes. Rust achieves this through its unique ownership system, which ensures memory safety without needing a garbage collector. We're expanding the integration of Rust into the Windows kernel to enhance the safety and reliability of Windows' codebase. This strategic move underscores our commitment to adopting modern technologies to improve the quality and security of Windows.

Learn more

- [Rust for Windows, and the windows crate](#)

Encryption and data protection

Article • 11/19/2024 • Applies to: [Windows 11](#)



When people travel with their PCs, their confidential information travels with them. Wherever confidential data is stored, it must be protected against unauthorized access, whether through physical device theft or from malicious applications.

BitLocker

BitLocker is a data protection feature that integrates with the operating system to address the threats of data theft or exposure from lost, stolen, or improperly decommissioned devices. It uses the AES algorithm in XTS or CBC mode with 128-bit or 256-bit key lengths to encrypt data on the volume. During the initial setup, when BitLocker is enabled during OOBE and the user signs into their Microsoft account for the first time, BitLocker automatically saves its recovery password to the Microsoft account for retrieval if needed. Users also have the option to export the recovery password if they manually enable BitLocker. Recovery key content can be saved to cloud storage on OneDrive or Azure^[4].

For organizations, BitLocker can be managed via group policy or with a device management solution like Microsoft Intune^[3]. It provides encryption for the OS, fixed data, and removable data drives (BitLocker To Go), using technologies such as Hardware Security Test Interface (HSTI), Modern Standby, UEFI Secure Boot, and TPM.

New in Windows 11, version 24H2

The BitLocker preboot recovery screen includes the Microsoft account (MSA) hint, if the recovery password is saved to an MSA. This hint helps the user to understand which MSA account was used to store recovery key information.

Learn more

- [BitLocker overview](#)

BitLocker To Go

BitLocker To Go refers to BitLocker on removable data drives. BitLocker To Go includes the encryption of USB flash drives, SD cards, and external hard disk drives. Drives can be unlocked using a password, certificate on a smart card, or recovery password.

 [Learn more](#)

- [BitLocker FAQ](#)

Device encryption

Device encryption is a Windows feature that simplifies the process of enabling BitLocker encryption on certain devices. It ensures that only the OS drive and fixed drives are encrypted, while external/USB drives remain unencrypted. Additionally, devices with externally accessible ports that allow DMA access are not eligible for device encryption. Unlike standard BitLocker implementation, device encryption is enabled automatically to ensure continuous protection. Once a clean installation of Windows is completed and the out-of-box experience is finished, the device is prepared for first use with encryption already in place.

Organizations have the option to disable device encryption in favor of a full BitLocker implementation. This allows for more granular control over encryption policies and settings, ensuring that the organization's specific security requirements are met.

 **New in Windows 11, version 24H2**

The Device encryption prerequisites of DMA and HSTI/Modern Standby are removed. This change makes more devices eligible for both automatic and manual device encryption.

 [Learn more](#)

- [Device encryption](#)

Encrypted hard drive

Encrypted hard drives are a class of hard drives that are self-encrypted at the hardware level. They allow for full-disk hardware encryption and are transparent to the user. These drives combine the security and management benefits provided by BitLocker, with the power of self-encrypting drives.

By offloading the cryptographic operations to hardware, encrypted hard drives increase BitLocker performance and reduce CPU usage and power consumption. Because

encrypted hard drives encrypt data quickly, BitLocker deployment can be expanded across enterprise devices with little to no impact on productivity.

Encrypted hard drives enable:

- Smooth performance: encryption hardware integrated into the drive controller allows the drive to operate at full data rate without performance degradation
- Strong security based in hardware: encryption is always-on, and the keys for encryption never leave the hard drive. The drive authenticates the user independently from the operating system before it unlocks
- Ease of use: encryption is transparent to the user, and the user doesn't need to enable it. Encrypted hard drives are easily erased using an onboard encryption key. There's no need to re-encrypt data on the drive
- Lower cost of ownership: there's no need for new infrastructure to manage encryption keys since BitLocker uses your existing infrastructure to store recovery information. Your device operates more efficiently because processor cycles don't need to be used for the encryption process

 **Learn more**

- [Encrypted hard drive](#)

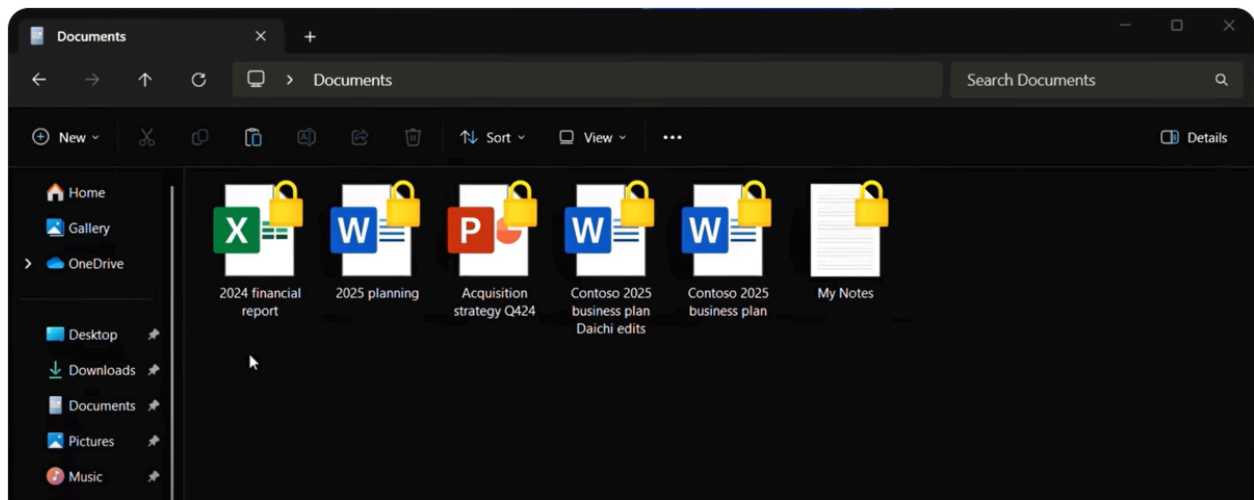
Personal Data Encryption

Personal Data Encryption is a user-authenticated encryption mechanism designed to protect user's content. Personal Data Encryption uses Windows Hello for Business as its modern authentication scheme, with PIN or biometric authentication methods. The encryption keys used by Personal Data Encryption are securely stored within the Windows Hello container. When a user signs in with Windows Hello, the container is unlocked, making the keys available to decrypt the user's content.

The initial release of Personal Data Encryption in Windows 11, version 22H2, introduced a set of public APIs that applications can adopt to safeguard content.

 **New in Windows 11, version 24H2**

Personal Data Encryption is further enhanced with *Personal Data Encryption for known folders*, which extends protection to the Windows folders: Documents, Pictures, and Desktop.



Learn more

- [Personal Data Encryption](#)

Email encryption

Email encryption allows users to secure email messages and attachments so that only the intended recipients with a digital identification (ID), or certificate, can read them^[8]. Users can also *digitally sign* a message, which verifies the sender's identity and ensures the message hasn't been tampered with.

The new Outlook app included in Windows 11 supports various types of email encryption, including Microsoft Purview Message Encryption, S/MIME, and Information Rights Management (IRM).

When using Secure/Multipurpose Internet Mail Extensions (S/MIME), users can send encrypted messages to people within their organization and to external contacts who have the proper encryption certificates. Recipients can only read encrypted messages if they have the corresponding decryption keys. If an encrypted message is sent to recipients whose encryption certificates aren't available, Outlook asks you to remove these recipients before sending the email.

Learn more

- [S/MIME for message signing and encryption in Exchange Online](#)
- [Get started with the new Outlook for Windows](#) 
- [Email encryption](#)

Network security

Article • 11/19/2024 • Applies to: [Windows 11](#)



Windows 11 raises the bar for network security, offering comprehensive protection to help people work with confidence from almost anywhere. To help reduce an organization's attack surface, network protection in Windows prevents people from accessing dangerous IP addresses and domains that may host phishing scams, exploits, and other malicious content. Using reputation-based services, network protection blocks access to potentially harmful, low-reputation domains and IP addresses.

New DNS and TLS protocol versions strengthen the end-to-end protections needed for applications, web services, and Zero Trust networking. File access adds an untrusted network scenario with Server Message Block over QUIC, and new encryption and signing capabilities. Wi-Fi and Bluetooth advancements also provide greater trust in connections to other devices. In addition, VPN and Windows Firewall platforms offer new ways to easily configure and debug software.

In enterprise environments, network protection works best with Microsoft Defender for Endpoint, which provides detailed reporting on protection events as part of larger investigation scenarios.

[i](#) **Learn more**

- [How to protect your network](#)

Transport Layer Security (TLS)

Transport Layer Security (TLS) is a popular security protocol, encrypting data in transit to help provide a more secure communication channel between two endpoints. Windows enables the latest protocol versions and strong cipher suites by default and offers a full suite of extensions such as client authentication for enhanced server security, or session resumption for improved application performance. TLS 1.3 is the latest version of the protocol and is enabled by default in Windows. This version helps to eliminate obsolete cryptographic algorithms, enhance security over older versions, and aim to encrypt as much of the TLS handshake as possible. The handshake is more performant with one less round trip per connection on average and supports only strong cipher suites which

provide perfect forward secrecy and less operational risk. Using TLS 1.3 provides more privacy and lower latencies for encrypted online connections. If the client or server application on either side of the connection doesn't support TLS 1.3, the connection falls back to TLS 1.2. Windows uses the latest Datagram Transport Layer Security (DTLS) 1.2 for UDP communications.

Learn more

- [TLS/SSL overview \(Schannel SSP\)](#)
- [TLS 1.0 and TLS 1.1 soon to be disabled in Windows](#) 

Domain Name System (DNS) security

In Windows 11, the Windows DNS client supports DNS over HTTPS and DNS over TLS, two encrypted DNS protocols. These allow administrators to ensure their devices protect their name queries from on-path attackers, whether they're passive observers logging browsing behavior or active attackers trying to redirect clients to malicious sites. In a Zero Trust model where no trust is placed in a network boundary, having a secure connection to a trusted name resolver is required.

Windows 11 provides group policy and programmatic controls to configure DNS over HTTPS behavior. As a result, IT administrators can extend existing security to adopt new models such as Zero Trust. IT administrators can mandate DNS over HTTPS protocol, ensuring that devices that use insecure DNS will fail to connect to network resources. IT administrators also have the option not to use DNS over HTTPS or DNS over TLS for legacy deployments where network edge appliances are trusted to inspect plain-text DNS traffic. By default, Windows 11 will defer to the local administrator on which resolvers should use encrypted DNS.

Support for DNS encryption integrates with existing Windows DNS configurations such as the Name Resolution Policy Table (NRPT), the system Hosts file, and resolvers specified per network adapter or network profile. The integration helps Windows 11 ensure that the benefits of greater DNS security do not regress existing DNS control mechanisms.

Bluetooth protection

The number of Bluetooth devices connected to Windows 11 continues to increase. Windows users connect their Bluetooth headsets, mice, keyboards, and other accessories and improve their day-to-day PC experience by enjoying streaming, productivity, and gaming. Windows supports all standard Bluetooth pairing protocols,

including classic and LE Secure connections, secure simple pairing, and classic and LE legacy pairing. Windows also implements host-based LE privacy. Windows updates help users stay current with OS and driver security features in accordance with the Bluetooth Special Interest Group (SIG) and Standard Vulnerability Reports, as well as issues beyond those required by the Bluetooth core industry standards. Microsoft strongly recommends that Bluetooth accessories' firmware and software are kept up to date.

IT-managed environments have a number of policy settings available via configuration service providers, group policy, and PowerShell. These settings can be managed through device management solutions like Microsoft Intune^[4]. You can configure Windows to use Bluetooth technology while supporting the security needs of your organization. For example, you can allow input and audio while blocking file transfer, force encryption standards, limit Windows discoverability, or even disable Bluetooth entirely for the most sensitive environments.

Learn more

- [Policy CSP - Bluetooth](#)

Wi-Fi connections

Windows Wi-Fi supports industry-standard authentication and encryption methods when connecting to Wi-Fi networks. WPA (Wi-Fi Protected Access) is a security standard defined by the Wi-Fi Alliance (WFA) to provide sophisticated data encryption and better user authentication.

The current security standard for Wi-Fi authentication is WPA3, which provides a more secure and reliable connection method as compared to WPA2 and older security protocols. Windows supports three WPA3 modes - WPA3 Personal, WPA3 Enterprise, and WPA3 Enterprise 192-bit Suite B.

Windows 11 includes WPA3 Personal with the new H2E protocol and WPA3 Enterprise 192-bit Suite B. Windows 11 also supports WPA3 Enterprise, which includes enhanced server certificate validation and TLS 1.3 for authentication using EAP-TLS authentication.

Opportunistic Wireless Encryption (OWE), a technology that allows wireless devices to establish encrypted connections to public Wi-Fi hotspots, is also included.

5G and eSIM

5G networks use stronger encryption and better network segmentation compared to previous generations of cellular protocols. Unlike Wi-Fi, 5G access is always mutually

authenticated. Access credentials are stored in an EAL4-certified eSIM that is physically embedded in the device, making it much harder for attackers to tamper with. Together, 5G and eSIM provide a strong foundation for security.

Learn more

- [eSIM configuration of a download server](#)

Windows Firewall

Windows Firewall is an important part of a layered security model. It provides host-based, two-way network traffic filtering, blocking unauthorized traffic flowing into or out of the local device based on the types of networks the device is connected to.

Windows Firewall offers the following benefits:

- Reduces the risk of network security threats: Windows Firewall reduces the attack surface of a device with rules that restrict or allow traffic by many properties, such as IP addresses, ports, or program paths. This functionality increases manageability and decreases the likelihood of a successful attack
- Safeguards sensitive data and intellectual property: By integrating with Internet Protocol Security (IPSec), Windows Firewall provides a simple way to enforce authenticated, end-to-end network communications. It provides scalable, tiered access to trusted network resources, helping to enforce integrity of the data, and optionally helping to protect the confidentiality of the data
- Extends the value of existing investments: Because Windows Firewall is a host-based firewall that is included with the operating system, there's no extra hardware or software required. Windows Firewall is also designed to complement existing non-Microsoft network security solutions through a documented application programming interface (API)

Windows 11 makes the Windows Firewall easier to analyze and debug. IPSec behavior is integrated with Packet Monitor, an in-box, cross-component network diagnostic tool for Windows. Additionally, the Windows Firewall event logs are enhanced to ensure an audit can identify the specific filter that was responsible for any given event. This enables analysis of firewall behavior and rich packet capture without relying on third-party tools.

Admins can configure more settings through the Firewall and Firewall Rule policy templates in the Endpoint Security node in Microsoft Intune^[4], using the platform support from the Firewall configuration service provider (CSP) and applying these settings to Windows endpoints.

New in Windows 11, version 24H2

The Firewall Configuration Service Provider (CSP) in Windows now enforces an all-or-nothing approach to applying firewall rules within each atomic block. Previously, if the CSP encountered an issue with any rule in a block, it would not only stop processing that rule but also cease processing subsequent rules, potentially leaving a security gap with partially deployed rule blocks. Now, if any rule in the block cannot be successfully applied, the CSP stops processing subsequent rules and roll back all rules from that atomic block, eliminating the ambiguity of partially deployed rule blocks.

Learn more

- [Windows Firewall overview](#)
- [Firewall CSP](#)

Virtual private networks (VPN)

Organizations have long relied on Windows to provide reliable, secured, and manageable virtual private network (VPN) solutions. The Windows VPN client platform includes built-in VPN protocols, configuration support, a common VPN user interface, and programming support for custom VPN protocols. VPN apps are available in the Microsoft Store for both enterprise and consumer VPNs, including apps for the most popular enterprise VPN gateways.

In Windows 11, we've integrated the most commonly used VPN controls right into the Windows 11 Quick Actions pane. From the Quick Actions pane, users can verify the status of their VPN, start and stop the connection, and easily open Settings for more controls.

The Windows VPN platform connects to Microsoft Entra ID^[4] and Conditional Access for single sign-on, including multifactor authentication (MFA) through Microsoft Entra ID. The VPN platform also supports classic domain-joined authentication. It's supported by Microsoft Intune^[4] and other device management solutions. The flexible VPN profile supports both built-in protocols and custom protocols. It can configure multiple authentication methods and can be automatically started as needed or manually started by the end user. It also supports split-tunnel VPN and exclusive VPN with exceptions for trusted external sites.

With Universal Windows Platform (UWP) VPN apps, end users never get stuck on an old version of their VPN client. VPN apps from the store will be automatically updated as needed. Naturally, the updates are in the control of your IT admins.

The Windows VPN platform is tuned and hardened for cloud-based VPN providers like Azure VPN. Features like Microsoft Entra ID authentication, Windows user interface integration, plumbing IKE traffic selectors, and server support are all built into the Windows VPN platform. The integration into the Windows VPN platform leads to a simpler IT admin experience. User authentication is more consistent, and users can easily find and control their VPN.

i Learn more

- [Windows VPN technical guide](#)

Server Message Block file services

Server Message Block (SMB) and file services are the most common Windows workloads in the commercial and public sector ecosystem. Users and applications rely on SMB to access the files that run organizations of all sizes.

Windows 11 introduced significant security updates to meet today's threats, including AES-256 SMB encryption, accelerated SMB signing, Remote Directory Memory Access (RDMA) network encryption, and SMB over QUIC for untrusted networks.

NEW New in Windows 11, version 24H2

New security options include mandatory SMB signing by default, NTLM blocking, authentication rate limiting, and several other enhancements.

i Learn more

- [Server Message Block \(SMB\) protocol changes in Windows 11, version 24H2](#)
- [File sharing using the SMB 3 protocol](#)

Virus and threat protection in Windows 11

Article • 11/19/2024 • Applies to: [Windows 11](#)



Today's threat landscape is more complex than ever. This new world requires a new approach to threat prevention, detection, and response. Microsoft Defender Antivirus, along with many other features that are built into Windows 11, is at the frontlines, protecting customers against current and emerging threats.

Microsoft Defender SmartScreen

Microsoft Defender SmartScreen protects against phishing, malware websites and applications, and the downloading of potentially malicious files.

SmartScreen determines whether a site is potentially malicious by:

- Analyzing visited webpages to find indications of suspicious behavior. If it determines a page is suspicious, it will show a warning page advising caution
- Checking the visited sites against a dynamic list of reported phishing sites and malicious software sites. If it finds a match, SmartScreen warns that the site might be malicious

SmartScreen also determines whether a downloaded app or app installer is potentially malicious by:

- Checking downloaded files against a list of reported malicious software sites and programs known to be unsafe. If it finds a match, SmartScreen warns that the file might be malicious
- Checking downloaded files against a list of well-known files. If the file is of a dangerous type and not well-known, SmartScreen displays a caution alert

With enhanced phishing protection in Windows 11, SmartScreen also alerts people when they're entering their Microsoft credentials into a potentially risky location, regardless of which application or browser is used. IT can customize which notifications appear through Microsoft Intune^[4]. This protection runs in audit mode by default, giving IT admins full control to make decisions around policy creation and enforcement.

Because Windows 11 comes with these enhancements already built in and enabled, users have extra security from the moment they turn on their device.

The app and browser control section contains information and settings for Microsoft Defender SmartScreen. IT administrators and IT pros can get configuration guidance in the [Microsoft Defender SmartScreen documentation library](#).

Network protection

While Microsoft Defender SmartScreen works with Microsoft Edge, for third-party browsers and processes, Windows 11 has Network protection that protects against phishing scams, malware websites, and the downloading of potentially malicious files.

When using Network Protection with Microsoft Defender for Endpoint, you'll be able to use Indicators of Compromise to block specific URL's and/or ip addresses. Also integrates with Microsoft Defender for Cloud Apps to block unsanctioned web apps in your organization. Allow or block access to websites based on category with Microsoft Defender for Endpoint's Web Content Filtering.

[Network Protection library](#) [Web protection library](#)

Tamper protection

Attacks like ransomware attempt to disable security features, such as anti-virus protection. Bad actors like to disable security features to get easier access to user's data, to install malware, or otherwise exploit user's data, identity, and devices without fear of being blocked. Tamper protection helps prevent these kinds of activities.

With tamper protection, malware is prevented from taking actions such as:

- Disabling real-time protection
- Turning off behavior monitoring
- Disabling antivirus protection, such as Scan all downloaded files and attachments (IOOfficeAntivirus (IOAV))
- Disabling cloud-delivered protection
- Removing security intelligence updates
- Disabling automatic actions on detected threats
- Disabling archived files
- Altering exclusions
- Disabling notifications in the Windows Security app

[i](#) **Learn more**

- [Tamper protection](#)

Microsoft Defender Antivirus

Microsoft Defender Antivirus is a next-generation protection solution included in all versions of Windows 10 and Windows 11. From the moment you turn on Windows, Microsoft Defender Antivirus continually monitors for malware, viruses, and security threats. In addition to real-time protection, updates are downloaded automatically to help keep your device safe and protect it from threats. If you have another antivirus app installed and turned on, Microsoft Defender Antivirus turns off automatically. If you uninstall the other app, Microsoft Defender Antivirus turns back on.

Microsoft Defender Antivirus includes real-time, behavior-based, and heuristic antivirus protection. This combination of always-on content scanning, file and process behavior monitoring, and other heuristics effectively prevents security threats. Microsoft Defender Antivirus continually scans for malware and threats and also detects and blocks potentially unwanted applications (PUA), applications deemed to negatively impact your device but aren't considered malware.

Microsoft Defender Antivirus always-on protection is integrated with cloud-delivered protection, which helps ensure near-instant detection and blocking of new and emerging threats. This combination of local and cloud-delivered technologies including advanced memory scanning, behavior monitoring, and machine learning, provides award-winning protection at home and at work.



i Learn more

- [Microsoft Defender Antivirus in Windows Overview.](#)

Attack surface reduction rules

Attack surface reduction rules help prevent actions and applications or scripts that are often abused to compromise devices and networks. By controlling when and how executables and/or script can run, thereby reducing the attack surface, you can reduce the overall vulnerability of your organization. Administrators can configure specific attack surface reduction rules to help block certain behaviors, such as:

- Launching executable files and scripts that attempt to download or run files
- Running obfuscated or otherwise suspicious scripts
- Performing behaviors that apps don't usually initiate during normal day-to-day work

For example, an attacker might try to run an unsigned script from a USB drive or have a macro in an Office document make calls directly to the Win32 API. Attack surface reduction rules can constrain these kinds of risky behaviors and improve the defensive posture of the device. For comprehensive protection, follow steps for enabling hardware-based isolation

For Microsoft Edge and reducing the attack surface across applications, folders, device, network, and firewall.

 [Learn more](#)

- [Attack surface reduction](#)

Controlled folder access

You can protect your valuable information in specific folders by managing app access to them. Only trusted apps can access protected folders, which are specified when controlled folder access is configured. Typically, commonly used folders, such as those used for documents, pictures, and downloads, are included in the list of controlled folders.

Controlled folder access works with a list of trusted apps. Apps that are included in the list of trusted software work as expected. Apps that aren't included in the trusted list are prevented from making any changes to files inside protected folders.

Controlled folder access helps protect user's valuable data from malicious apps and threats such as ransomware.

 [Learn more](#)

- [Controlled folder access](#)

Exploit Protection

Exploit Protection automatically applies several exploit mitigation techniques to operating system processes and apps. Exploit Protection works best with Microsoft Defender for Endpoint^[4], which gives organizations detailed reporting into Exploit Protection events and blocks as part of typical alert investigation scenarios. You can enable Exploit Protection on an individual device and then use policy settings to distribute the configuration XML file to multiple devices simultaneously.

When a mitigation is encountered on the device, a notification will be displayed from the Action Center. You can customize the notification with your company details and

contact information. You can also enable the rules individually to customize which techniques the feature monitors.

You can use audit mode to evaluate how Exploit Protection would impact your organization if it were enabled. And go through safe deployment practices (SDP).

Windows 11 provides configuration options for Exploit Protection. You can prevent users from modifying these specific options with device management solutions like Microsoft Intune or group policy.

** Learn more**

- [Protecting devices from exploits](#)

Application security

Article • 11/19/2024 • Applies to: [Windows 11](#)



Application Security

Applications are prime vectors for cyberattacks due to their frequent usage and access to valuable data. Common attempts include injection attacks that insert malicious code, man-in-the-middle attacks that intercept and potentially alter communication between

users and applications, and various methods of tricking users into divulging sensitive information or changing system settings.

Windows 11 protects users, apps, and data with features like Windows App Control for Business and the Microsoft vulnerable driver blocklist, which help ensure that only trusted apps and drivers can run on the device.



Application and driver control

Article • 12/11/2024 • Applies to: [Windows 11](#)



Smart App Control

Smart App Control prevents users from running malicious applications by blocking untrusted or unsigned applications. Smart App Control goes beyond previous built-in browser protections by adding another layer of security that is woven directly into the core of the OS at the process level. Using AI, Smart App Control only allows processes to run if they're predicted to be safe based on existing and new intelligence updated daily.

Smart App Control builds on top of the same cloud-based AI used in *App Control for Business* to predict the safety of an application, so that users can be confident that their applications are safe and reliable. Additionally, Smart App Control blocks unknown script files and macros from the web, greatly improving security for everyday users.

We've been making significant improvements to Smart App Control to increase the security, usability, and cloud intelligence response for apps in the Windows ecosystem. Users can get the latest and best experience with Smart App Control by keeping their devices up to date via Windows Update every month.

To ensure that users have a seamless experience with Smart App Control enabled, we ask developers to sign their applications with a code signing certificate from the Microsoft Trusted Root Program. Developers should include all binaries, such as exe, dll, temp installer files, and uninstallers. Trusted Signing makes the process of obtaining, maintaining, and signing with a trusted certificate simple and secure.

Smart App Control is disabled on devices enrolled in enterprise management. We suggest enterprises running line-of-business applications continue to use *App Control for Business*.

[i](#) Learn more

- [Smart App Control](#)

App Control for Business

Your organization is only as secure as the applications that run on your devices. With *application control*, apps must earn trust to run, in contrast to an application trust model where all code is assumed trustworthy. By helping prevent unwanted or malicious code from running, application control is an important part of an effective security strategy. Many organizations cite application control as one of the most effective means of defending against executable file-based malware.

App Control for Business (previously called *Windows Defender Application Control*) and AppLocker are both included in Windows. App Control for Business is the next-generation app control solution for Windows and provides powerful control over what runs in your environment. Organizations that were using AppLocker on previous versions of Windows, can continue to use the feature as they consider whether to switch to App Control for Business for stronger protection.

Microsoft Intune^[4] can configure App Control for Business in the admin console, including setting up Intune as a managed installer. Intune includes built-in options for App Control for Business and the possibility to upload policies as an XML file for Intune to package and deploy.

Learn more

- [Application Control for Windows](#)
- [Automatically allow apps deployed by a managed installer with App Control for Business](#)

SOON Administrator protection

When users sign in with administrative rights to Windows, they have the power to make significant changes to the system, which can impact its overall security. These rights can be a target for malicious software.

Administrator protection is a new security feature in Windows 11 designed to safeguard these administrative rights. It allows administrators to perform all necessary functions with **just-in-time administrative rights**, while running most tasks without administrative privileges. The goal of administrator protection is to provide a secure and seamless experience, ensuring users operate with the least required privileges.

When administrator protection is enabled, if an app needs special permissions like administrative rights, the user is asked for approval. When an approval is needed, Windows Hello provides a secure and easy way to approve or deny these requests.

Note

Administrator protection is currently in preview. For devices running previous versions of Windows, refer to [User Account Control \(UAC\)](#).

Microsoft vulnerable driver blocklist

The Windows kernel is the most privileged software and is therefore a compelling target for malware authors. Since Windows has strict requirements for code running in the kernel, cybercriminals commonly exploit vulnerabilities in kernel drivers to get access. Microsoft works with ecosystem partners to constantly identify and respond to potentially vulnerable kernel drivers. To prevent vulnerable versions of drivers from running, Windows has a *block policy* turned on by default. Users can configure the policy from the Windows Security app.

 [Learn more](#)

- [Microsoft recommended driver block rules](#)

Trusted Signing

Trusted Signing is a Microsoft fully managed, end-to-end signing solution that simplifies the signing process and empowers third-party developers to easily build and distribute applications.

 [Learn more](#)

- [What is Trusted Signing](#)

Application isolation

Article • 12/11/2024 • Applies to: [Windows 11](#)



NEW Win32 app isolation

Win32 app isolation is a security feature designed to be the default isolation standard on Windows clients. It's built on [AppContainer](#), and offers several added security features to help the Windows platform defend against attacks that use vulnerabilities in applications or third-party libraries. To isolate their applications, developers can update them using Visual Studio.

Win32 app isolation follows a two-step process:

- In the first step, the Win32 application is launched as a low-integrity process using AppContainer, which is recognized as a security boundary by Windows. The process is limited to a specific set of Windows APIs by default and is unable to inject code into any process operating at a higher integrity level
- In the second step, least privilege is enforced by granting authorized access to Windows securable objects. This access is determined by capabilities that are added to the application manifest through MSIX packaging. *Securable objects* in this context refers to Windows resources whose access is safeguarded by capabilities. These capabilities enable the implantation of a [Discretionary Access Control List](#) on Windows

To help ensuring that isolated applications run smoothly, developers must define the access requirements for the application via access capability declarations in the application package manifest. The *Application Capability Profiler (ACP)* simplifies the entire process by allowing the application to run in *learn mode* with low privileges. Instead of denying access if the capability isn't present, ACP allows access and logs additional capabilities required for access if the application were to run isolated.

To create a smooth user experience that aligns with nonisolated, native Win32 applications, two key factors should be taken into consideration:

- Approaches for accessing data and privacy information
- Integrating Win32 apps for compatibility with other Windows interfaces

The first factor relates to implementing methods to manage access to files and privacy information within and outside the isolation boundary AppContainer. The second factor involves integrating Win32 apps with other Windows interfaces in a way that helps enable seamless functionality without causing perplexing user consent prompts.

Learn more

- [Win32 app isolation overview](#)
- [Application Capability Profiler \(ACP\)](#)
- [Packaging a Win32 app isolation application with Visual Studio](#)
- [Sandboxing Python with Win32 app isolation](#) 

App containers

In addition to Windows Sandbox for Win32 apps, Universal Windows Platform (UWP) applications run in Windows containers known as *app containers*. App containers act as process and resource isolation boundaries, but unlike Docker containers, these are special containers designed to run Windows applications.

Processes that run in app containers operate at a low integrity level, meaning they have limited access to resources they don't own. Because the default integrity level of most resources is medium integrity level, the UWP app can access only a subset of the file system, registry, and other resources. The app container also enforces restrictions on network connectivity. For example, access to a local host isn't allowed. As a result, malware or infected apps have limited footprint for escape.

Learn more

- [Windows and app container](#)

Windows Sandbox

Windows Sandbox provides a lightweight desktop environment to safely run untrusted Win32 applications in isolation, using the same hardware-based virtualization technology as Hyper-V. Any untrusted Win32 app installed in Windows Sandbox stays only in the sandbox and can't affect the host.

Once Windows Sandbox is closed, nothing persists on the device. All the software with all its files and state are permanently deleted after the untrusted Win32 application is closed.

Learn more

- [Windows Sandbox](#)

Windows Subsystem for Linux (WSL)

With Windows Subsystem for Linux (WSL) you can run a Linux environment on a Windows device, without the need for a separate virtual machine or dual booting. WSL is designed to provide a seamless and productive experience for developers who want to use both Windows and Linux at the same time.

New in Windows 11, version 24H2

- **Hyper-V Firewall** is a network firewall solution that enables filtering of inbound and outbound traffic to/from WSL containers hosted by Windows
- **DNS Tunneling** is a networking setting that improves compatibility in different networking environments, making use of virtualization features to obtain DNS information rather than a networking packet
- **Auto proxy** is a networking setting that enforces WSL to use Windows' HTTP proxy information. Turn on when using a proxy on Windows, as it makes that proxy automatically apply to WSL distributions

These features can be set up using a device management solution such as Microsoft Intune^[7]. Microsoft Defender for Endpoint (MDE) integrates with WSL, allowing it to monitor activities within a WSL distro and report them to the MDE dashboards.

Learn more

- [Hyper-V Firewall](#)
- [DNS Tunneling](#)
- [Auto proxy](#)
- [Intune setting for WSL](#)
- [Microsoft Defender for Endpoint plug-in for WSL](#)

Virtualization-based security enclaves

A **Virtualization-based security enclave** is a software-based trusted execution environment (TEE) inside a host application. VBS enclaves enable developers to use VBS to protect their application's secrets from admin-level attacks.

VBS enclaves are available starting in Windows 11, version 24H2, and Windows Server 2025 on both x64 and ARM64.

Learn more

- Virtualization-based security enclave

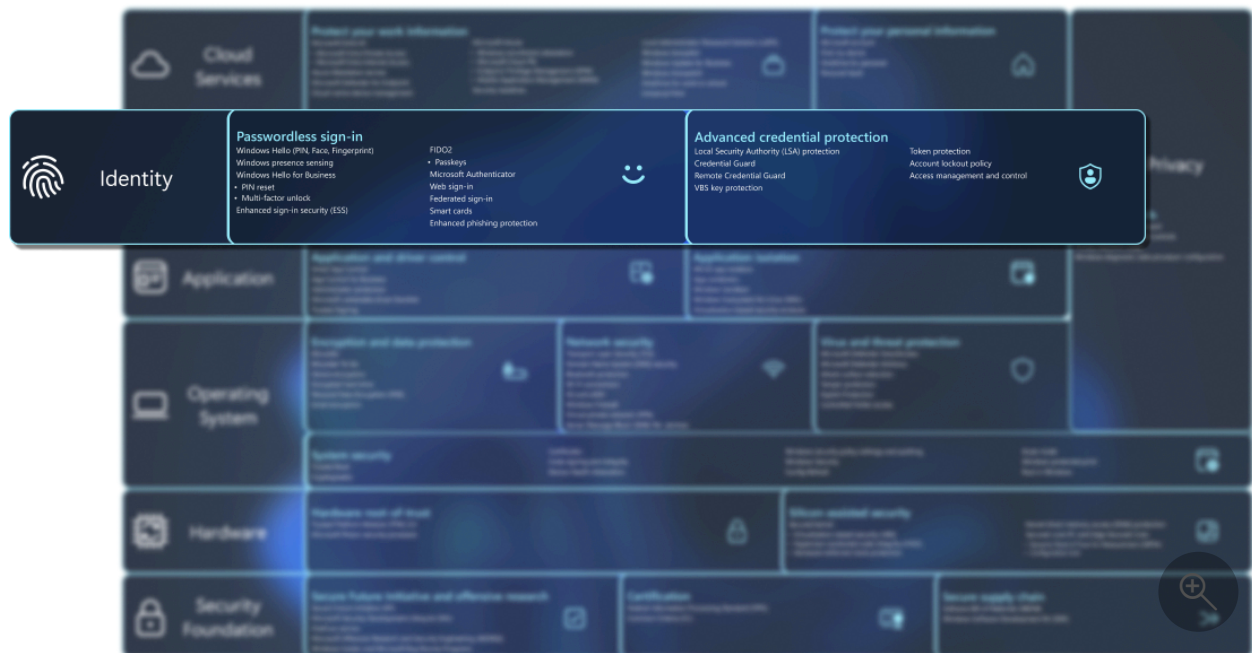
Identity protection

Article • 11/19/2024 • Applies to: [Windows 11](#)



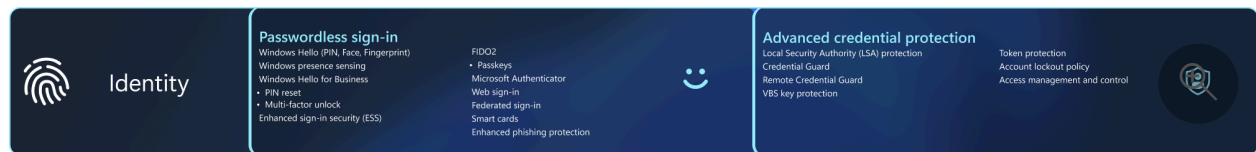
Employees are increasingly targets for cyberattacks in organizations, making identity protection a priority. Weak or reused passwords, password spraying, social engineering, and phishing are just a few of the risks businesses face today.

Identity protection in Windows 11 continuously evolves to provide organizations with the latest defenses, including Windows Hello for Business passwordless and Windows Hello Enhanced Sign-in Security (ESS). By leveraging these powerful identity safeguards, organizations of all sizes can reduce the risk of credential theft and unauthorized access to devices, data, and other company resources.



Passwordless sign-in

Article • 11/19/2024 • Applies to: [Windows 11](#)



Passwords are a fundamental part of digital security, but they're often inconvenient and vulnerable to cyberattacks. With Windows 11, users can enjoy passwordless protection, which offers a more secure and user-friendly alternative. After a secure authorization process, credentials are safeguarded by multiple layers of hardware and software security, providing users with seamless, passwordless access to their apps and cloud services.

Windows Hello

Too often, passwords are weak, stolen, or forgotten. Organizations are moving toward passwordless sign-in to reduce the risk of breaches, lower the cost of managing passwords, and improve productivity and satisfaction for their users and customers. Microsoft is committed to helping organizations move toward a secure, passwordless future with Windows Hello, a cornerstone of Windows security and identity protection.

Windows Hello can enable passwordless sign-in using biometric or PIN verification and provides built-in support for the FIDO2 passwordless industry standard. As a result, people no longer need to carry external hardware like a security key for authentication.

The secure, convenient sign-in experience can augment or replace passwords with a stronger authentication model based on a PIN or biometric data such as facial or fingerprint recognition secured by the Trusted Platform Module (TPM). Step-by-step guidance makes setup easy.

Using asymmetric keys provisioned in the TPM, Windows Hello protects authentication by binding a user's credentials to their device. Windows Hello validates the user based on either a PIN or biometrics match and only then allows the use of cryptographic keys bound to that user in the TPM.

PIN and biometric data stay on the device and can't be stored or accessed externally. Since the data can't be accessed by anyone without physical access to the device, credentials are protected against replay attacks, phishing, and spoofing as well as password reuse and leaks.

Windows Hello can authenticate users to a Microsoft account (MSA), identity provider services, or the relying parties that also implement the FIDO2 or WebAuthn standards.

 **Learn more**

- [Configure Windows Hello](#) 

Windows Hello PIN

The Windows Hello PIN, which can only be entered by someone with physical access to the device, can be used for strong multifactor authentication. The PIN is protected by the TPM and, like biometric data, never leaves the device. When a user enters their PIN, an authentication key is unlocked and used to sign a request sent to the authenticating server.

The TPM protects against threats including PIN brute-force attacks on lost or stolen devices. After too many incorrect guesses, the device locks. IT admins can set security policies for PINs, such as complexity, length, and expiration requirements.

 **New in Windows 11, version 24H2**

If your device doesn't have built-in biometrics, Windows Hello has been enhanced to use Virtualization-based Security (VBS) by default to isolate credentials. This added layer of protection helps guard against admin-level attacks. Even when you sign in with a PIN, your credentials are stored in a secure container, ensuring protection on devices with or without built-in biometric sensors.

Windows Hello biometric

Windows Hello biometric sign-in enhances both security and productivity with a quick and convenient sign-in experience. There's no need to enter your PIN; just use your biometric data for an easy and delightful sign-in.

Windows devices that support biometric hardware, such as fingerprint or facial recognition cameras, integrate directly with Windows Hello, enabling access to Windows client resources and services. Biometric readers for both face and fingerprint must comply with Windows Hello biometric requirements. Windows Hello facial recognition is designed to authenticate only from trusted cameras used at the time of enrollment.

If a peripheral camera is attached to the device after enrollment, it can be used for facial authentication once validated by signing in with the internal camera. For added security, external cameras can be disabled for use with Windows Hello facial recognition.

 [Learn more](#)

- [Windows Hello biometric requirements](#)

Windows presence sensing

Windows presence sensing^[9] provides another layer of data security protection for hybrid workers. Windows 11 devices can intelligently adapt to a user's presence to help them stay secure and productive, whether they're working at home, the office, or a public environment.

Windows presence sensing combines presence detection sensors with Windows Hello facial recognition to sign the user in hands-free and automatically locks the device when the user leaves. With adaptive dimming, the PC dims the screen when the user looks away on compatible devices with presence sensors. It's also easier than ever to configure presence sensors on devices, with easy enablement in the out-of-the-box experience and new links in Settings to help find presence sensing features. Device manufacturers can customize and build extensions for the presence sensor.

Privacy is top of mind and more important than ever. Customers want to have greater transparency and control over the use of their information. The new app privacy settings enable users to allow or block access to their presence sensor information. Users can decide on these settings during the initial Windows 11 setup.

Users can also take advantage of more granular settings to easily enable and disable differentiated presence sensing features like wake on approach, lock on leave, and adaptive dimming. We're also supporting developers with new APIs for presence sensing for third-party applications. Third-party applications can now access user presence information on devices with presence sensors.

 [Learn more](#)

- [Presence sensing](#)
- [Manage presence sensing settings in Windows 11](#) 

Windows Hello for Business

Windows Hello for Business extends Windows Hello to work with an organization's Active Directory and Microsoft Entra ID accounts. It provides single sign-on access to work or school resources such as OneDrive, work email, and other business apps.

Windows Hello for Business also gives IT admins the ability to manage PIN and other sign-in requirements for devices connecting to work or school resources.

After Windows Hello for Business is provisioned, users can use a PIN, face, or fingerprint to unlock credentials and sign into their Windows device.

Provisioning methods include:

- Passkeys (preview), which provide a seamless way for users to authenticate to Microsoft Entra ID without entering a username or password
- Temporary Access Pass (TAP), a time-limited passcode with strong authentication requirements issued through Microsoft Entra ID
- Existing multifactor authentication with Microsoft Entra ID, including the Microsoft Authenticator app

Windows Hello for Business enhances security by replacing traditional usernames and passwords with a combination of a security key or certificate and a PIN or biometric data. This setup securely maps the credentials to a user account.

There are various deployment models available for Windows Hello for Business, providing flexibility to meet the diverse needs of different organizations. Among these, the *Hybrid cloud Kerberos trust* model is recommended and considered the simplest for organizations operating in hybrid environments.

Learn more

- [Windows Hello for Business overview](#)
- [Enable passkeys \(FIDO2\) for your organization](#)

PIN reset

The Microsoft PIN Reset Service allows users to reset their forgotten Windows Hello PINs without requiring re-enrollment. After registering the service in the Microsoft Entra ID tenant, the capability must be enabled on the Windows devices using group policy or a device management solution like Microsoft Intune^[4].

Users can initiate a PIN reset from the Windows lock screen or from the sign-in options in Settings. The process involves authenticating and completing multifactor authentication to reset the PIN.

Learn more

- [PIN reset](#)

Multi-factor unlock

For organizations that need an extra layer of sign-in security, multi-factor unlock enables IT admins to configure Windows to require a combination of two unique trusted signals to sign in. Trusted signal examples include a PIN or biometric data (face or fingerprint) combined with either a PIN, Bluetooth, IP configuration, or Wi-Fi.

Multi-factor unlock is useful for organizations who need to prevent information workers from sharing credentials or need to comply with regulatory requirements for a two-factor authentication policy.

i [Learn more](#)

- [Multi-factor unlock](#)

Windows passwordless experience

Windows Hello for Business now support a fully passwordless experience.

IT admins can configure a policy on Microsoft Entra ID joined machines so users no longer see the option to enter a password when accessing company resources. Once the policy is configured, passwords are removed from the Windows user experience, both for device unlock and in-session authentication scenarios. However, passwords aren't eliminated from the identity directory yet. Users are expected to navigate through their core authentication scenarios using strong, phishing-resistant, possession-based credentials like Windows Hello for Business and FIDO2 security keys. If necessary, users can use passwordless recovery mechanisms such as Microsoft PIN reset service or web sign-in.

Users authenticate directly with Microsoft Entra ID, helping speed access to on-premises applications and other resources.

i [Learn more](#)

- [Windows passwordless experience](#)

Enhanced Sign-in Security (ESS)

Windows Hello supports Enhanced Sign-in Security, which uses specialized hardware and software components to raise the security bar even higher for biometric sign-in.

Enhanced Sign-in Security biometrics uses Virtualization-based security (VBS) and the TPM to isolate user authentication processes and data and secure the pathway by which the information is communicated.

These specialized components protect against a class of attacks that includes biometric sample injection, replay, and tampering. For example, fingerprint readers must implement Secure Device Connection Protocol, which uses key negotiation and a Microsoft-issued certificate to protect and securely store user authentication data. For facial recognition, components such as the Secure Devices (SDEV) table and process isolation with trustlets help prevent more attack classes.

Enhanced Sign-in Security is configured by device manufacturers during the manufacturing process and is most typically supported in secured-core PCs. For facial recognition, Enhanced Sign-in Security is supported by specific silicon and camera combinations - check with the specific device manufacturer. Fingerprint authentication is available across all processor types. Reach out to specific OEMs for support details.

Learn more

- [Windows Hello Enhanced Sign-in Security](#)

FIDO2

The FIDO Alliance, the Fast Identity Online industry standards body, was established to promote authentication technologies and standards that reduce reliance on passwords. FIDO Alliance and World Wide Web Consortium (W3C) worked together to define the Client to Authenticator Protocol (CTAP2) and Web Authentication (WebAuthn) specifications. These specifications are the industry standard for providing strong, phishing-resistant, user friendly, and privacy preserving authentication across the web and apps. FIDO standards and certifications are becoming recognized as the leading standard for creating secure authentication solutions across enterprises, governments, and consumer markets.

Windows 11 can also use external FIDO2 security keys for authentication alongside or in addition to Windows Hello and Windows Hello for Business, which is also a FIDO2-certified passwordless solution. As a result, Windows 11 can be used as a FIDO authenticator for many popular identity management services.

Passkeys

Windows 11 makes it much harder for hackers who exploit stolen passwords via phishing attacks by empowering users to replace passwords with passkeys. Passkeys are the cross-platform future of secure sign-in. Microsoft and other technology leaders are supporting passkeys across their platforms and services.

A passkey is a unique, unguessable cryptographic secret that is securely stored on the device. Instead of using a username and password to sign in to a website or application, Windows 11 users can create and use a passkey with Windows Hello, a third-party passkey provider, an external FIDO2 security key, or their mobile device. Passkeys on Windows work in any browsers or apps that support them for sign in.

Passkeys created and saved with Windows Hello are protected by Windows Hello or Windows Hello for Business. Users can sign in to the site or app using their face, fingerprint, or device PIN. Users can manage their passkeys from **Settings > Accounts > Passkeys**.

 **Coming soon**^[7]

The plug-in model for third-party passkey providers enables users to manage their passkeys with third-party passkey managers. This model ensures a seamless platform experience, regardless of whether passkeys are managed directly by Windows or by a third-party authenticator. When a third-party passkey provider is used, the passkeys are securely protected and managed by the third-party provider.



Windows Security



Choose where to save your passkey



1Password



Bitwarden



Microsoft account



Pixel



iPhone, iPad, or Android device



External security key



This Windows device

Cancel



i Learn more

- [Support for passkeys in Windows](#)
- [Enable passkeys \(FIDO2\) for your organization](#)

Microsoft Authenticator

The Microsoft Authenticator app, which runs on iOS and Android devices, helps keeping Windows 11 users secure and productive. Microsoft Authenticator with Microsoft Entra passkeys can be used as a phish-resistant method to bootstrap Windows Hello for Business.

Microsoft Authenticator also enables easy, secure sign-in for all online accounts using multifactor authentication, passwordless phone sign-in, phishing-resistant authentication (passkeys), or password autofill. The accounts in the Authenticator app are secured with a public/private key pair in hardware-backed storage such as the Keychain in iOS and Keystore on Android. IT admins can use different tools to nudge their users to set up the Authenticator app, provide them with extra context about where the authentication is coming from, and ensure that they're actively using it.

Individual users can back up their credentials to the cloud by enabling the encrypted backup option in settings. They can also see their sign-in history and security settings for Microsoft personal, work, or school accounts.

Using this secure app for authentication and authorization enables people to be in control of how, where, and when their credentials are used. To keep up with an ever-changing security landscape, the app is constantly updated, and new capabilities are added to stay ahead of emerging threat vectors.

Learn more

- [Authentication methods in Microsoft Entra ID - Microsoft Authenticator app](#)

Web sign-in

With the support of web sign-in, users can sign in without a password using the Microsoft Authenticator app or a Temporary Access Pass (TAP). Web sign in also enables federated sign in with a SAML-P identity provider.

Learn more

- [Web sign-in for Windows](#)

Federated sign-in

Windows 11 supports federated sign-in with external education identity management services. For students unable to type easily or remember complex passwords, this

capability enables secure sign-in through methods like QR codes or pictures.

Learn more

- [Configure federated sign-in for Windows devices](#)

Smart cards

Organizations can also opt for smart cards, an authentication method that existed before biometric authentication. These tamper-resistant, portable storage devices enhance Windows security by authenticating users, signing code, securing e-mails, and signing in with Windows domain accounts.

Smart cards provide:

- Ease of use in scenarios such as healthcare, where users need to sign in and out quickly without using their hands or when sharing a workstation
- Isolation of security-critical computations that involve authentication, digital signatures, and key exchange from other parts of the computer. These computations are performed on the smart card
- Portability of credentials and other private information between computers at work, home, or on the road

Smart cards can only be used to sign in to domain accounts or Microsoft Entra ID accounts.

When a password is used to sign in to a domain account, Windows uses the Kerberos Version 5 (V5) protocol for authentication. If you use a smart card, the operating system uses Kerberos V5 authentication with X.509 V3 certificates. On Microsoft Entra ID joined devices, a smart card can be used with Microsoft Entra ID certificate-based authentication. Smart cards can't be used with local accounts.

Windows Hello for Business and FIDO2 security keys are modern, two-factor authentication methods for Windows. Customers using virtual smart cards are encouraged to move to Windows Hello for Business or FIDO2. For new Windows installations, we recommend Windows Hello for Business or FIDO2 security keys.

Learn more

- [Smart Card technical reference](#)

Enhanced phishing protection in Microsoft Defender SmartScreen

As malware protection and other safeguards evolve, cybercriminals look for new ways to circumvent security measures. Phishing is a leading threat, with apps and websites designed to steal credentials by tricking people into voluntarily entering passwords. As a result, many organizations are transitioning to the ease and security of passwordless sign-in with Windows Hello or Windows Hello for Business.

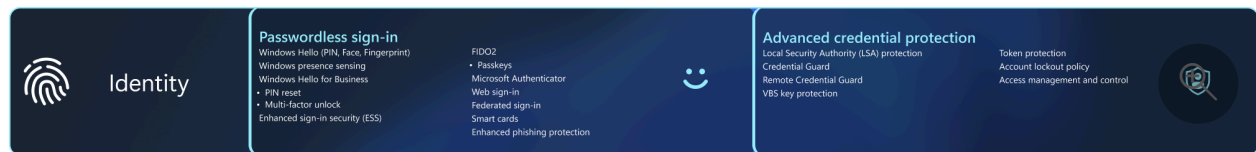
We know that people are in different parts of their passwordless journey. To help on that journey for people still using passwords, Windows 11 offers powerful credential protection. Microsoft Defender SmartScreen now includes enhanced phishing protection to automatically detect when a user's Microsoft password is entered into any app or website. Windows then identifies if the app or site is securely authenticating to Microsoft and warns if the credentials are at risk. Because the user is alerted at the moment of potential credential theft, they can take preemptive action before the password is used against them or their organization.

 **Learn more**

- [Enhanced phishing protection in Microsoft Defender SmartScreen](#)

Advanced credential protection

Article • 11/19/2024 • Applies to: [Windows 11](#)



In addition to adopting passwordless sign-in, organizations can strengthen security for user and domain credentials in Windows 11 with Credential Guard and Remote Credential Guard.

Local Security Authority (LSA) protection

Windows has several critical processes to verify a user's identity. Verification processes include Local Security Authority (LSA), which is responsible for authenticating users, and verifying Windows sign-ins. LSA handles tokens and credentials that are used for single sign-on to a Microsoft account and Entra ID account.

By loading only trusted, signed code, LSA provides significant protection against credential theft. LSA protection supports configuration using group policy and other device management solutions.

New in Windows 11, version 24H2

To help keep these credentials safe, LSA protection is enabled by default on all devices (MSA, Microsoft Entra joined, hybrid, and local). For new installs, it is enabled immediately. For upgrades, it is enabled after rebooting after an evaluation period of 10 days.

Users have the ability to manage the LSA protection state in the Windows Security application under **Device Security > Core Isolation > Local Security Authority protection**.

To ensure a seamless transition and enhanced security for all users, the enterprise policy for LSA protection takes precedence over enablement on upgrade.

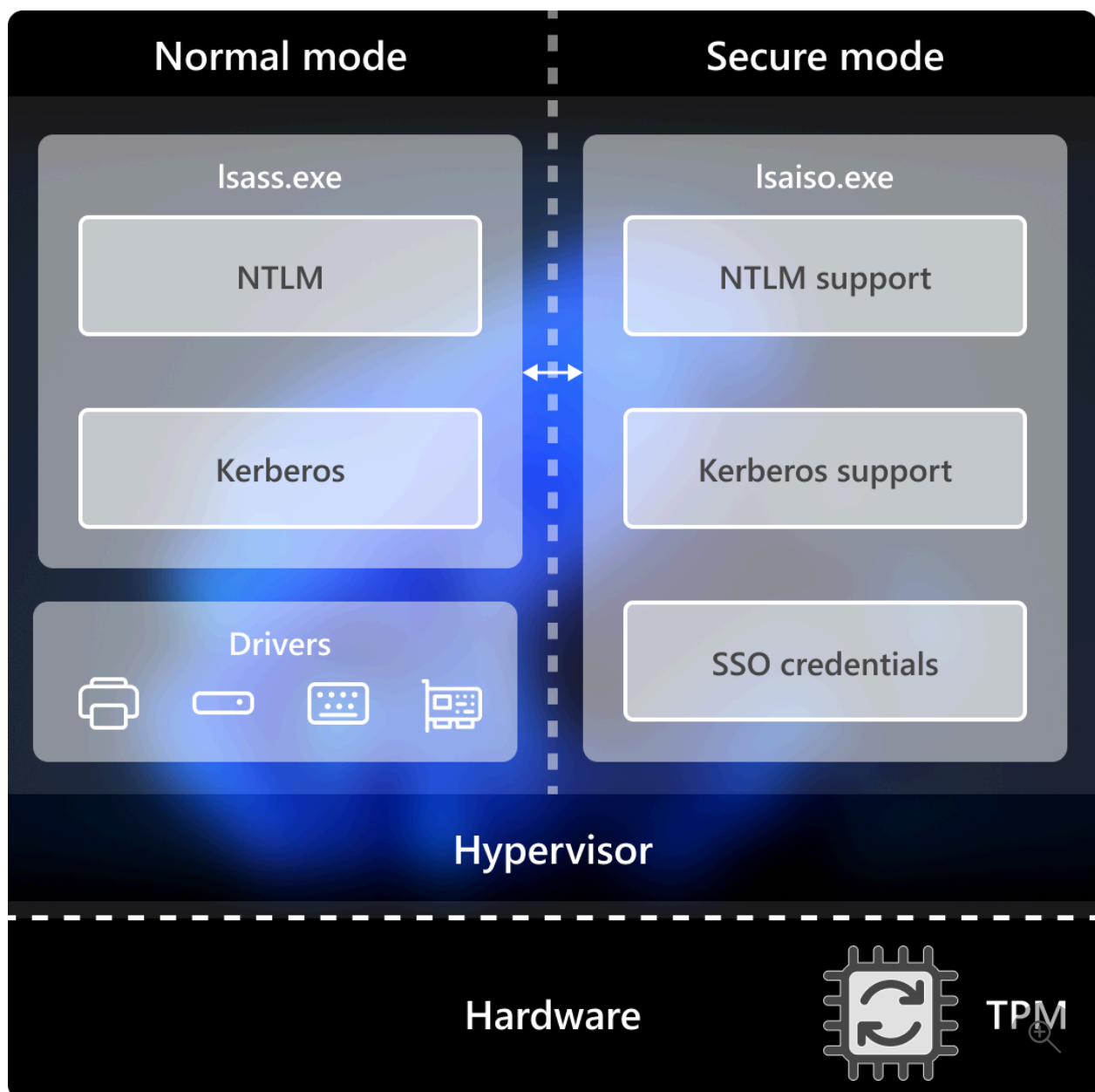
Learn more

- [Configuring additional LSA protection](#)

Credential Guard

Credential Guard uses hardware-backed, Virtualization-based security (VBS) to protect against credential theft. With Credential Guard, the Local Security Authority (LSA) stores and protects Active Directory (AD) secrets in an isolated environment that isn't accessible to the rest of the operating system. LSA uses remote procedure calls to communicate with the isolated LSA process.

By protecting the LSA process with Virtualization-based security, Credential Guard shields systems from user credential theft attack techniques like Pass-the-Hash or Pass-the-Ticket. It also helps prevent malware from accessing system secrets even if the process is running with admin privileges.



New in Windows 11, version 24H2

Credential Guard protections are expanded to optionally include machine account passwords for Active Directory-joined devices. Administrators can enable audit mode or enforcement of this capability using Credential Guard policy settings.

 [Learn more](#)

- [Protect derived domain credentials with Credential Guard](#)

Remote Credential Guard

Remote Credential Guard helps organizations protect credentials over a Remote Desktop connection by redirecting the Kerberos requests back to the device that is requesting the connection. It also provides single sign-on experiences for Remote Desktop sessions.

Administrator credentials are highly privileged and must be protected. When Remote Credential Guard is configured to connect during Remote Desktop sessions, the credential and credential derivatives are never passed over the network to the target device. If the target device is compromised, the credentials aren't exposed.

 [Learn more](#)

- [Remote Credential Guard](#)

VBS key protection

VBS key protection enables developers to secure cryptographic keys using Virtualization-based security (VBS). VBS uses the virtualization extension capability of the CPU to create an isolated runtime outside of the normal OS. When in use, VBS keys are isolated in a secure process, allowing key operations to occur without ever exposing the private key material outside of this space. At rest, private key material is encrypted by a TPM key, which binds VBS keys to the device. Keys protected in this way can't be dumped from process memory or exported in plain text from a user's machine, preventing exfiltration attacks by any admin-level attacker.

 [Learn more](#)

- [Advancing key protection in Windows using VBS](#) 

Token protection (preview)

Token protection attempts to reduce attacks using Microsoft Entra ID token theft. Token protection makes tokens usable only from their intended device by cryptographically binding a token with a device secret. When using the token, both the token and proof of the device secret must be provided. Conditional Access policies^[4] can be configured to require token protection when using sign-in tokens for specific services.

[i Learn more](#)

- [Token protection in Entra ID Conditional Access](#)

Sign-in session token protection policy

This feature allows applications and services to cryptographically bind security tokens to the device, restricting attackers' ability to impersonate users on a different device if tokens are stolen.

Account lockout policies

New devices with Windows 11 installed will have account lockout policies that are secure by default. These policies mitigate brute-force attacks such as hackers attempting to access Windows devices via the Remote Desktop Protocol (RDP).

The account lockout threshold policy is now set to 10 failed sign-in attempts by default, with the account lockout duration set to 10 minutes. The *Allow Administrator account lockout* is now enabled by default. The Reset account lockout counter after is now set to 10 minutes by default as well.

[i Learn more](#)

- [Account lockout policy](#)

Access management and control

Access control in Windows ensures that shared resources are available to users and groups other than the resource's owner and are protected from unauthorized use. IT administrators can manage the access of users, groups, and computers to objects and assets on a network or computer. After a user is authenticated, Windows implements the second phase of protecting resources with built-in authorization and access control technologies. These technologies determine if an authenticated user has the correct permissions.

Access Control Lists (ACLs) describe the permissions for a specific object and can also contain System Access Control Lists (SACLs). SACLs provide a way to audit specific system level events, such as when a user attempts to access file system objects. These events are essential for tracking activity for objects that are sensitive or valuable and require extra monitoring. Being able to audit when a resource attempts to read or write part of the operating system is critical to understanding a potential attack.

IT administrators can refine the application and management of access to:

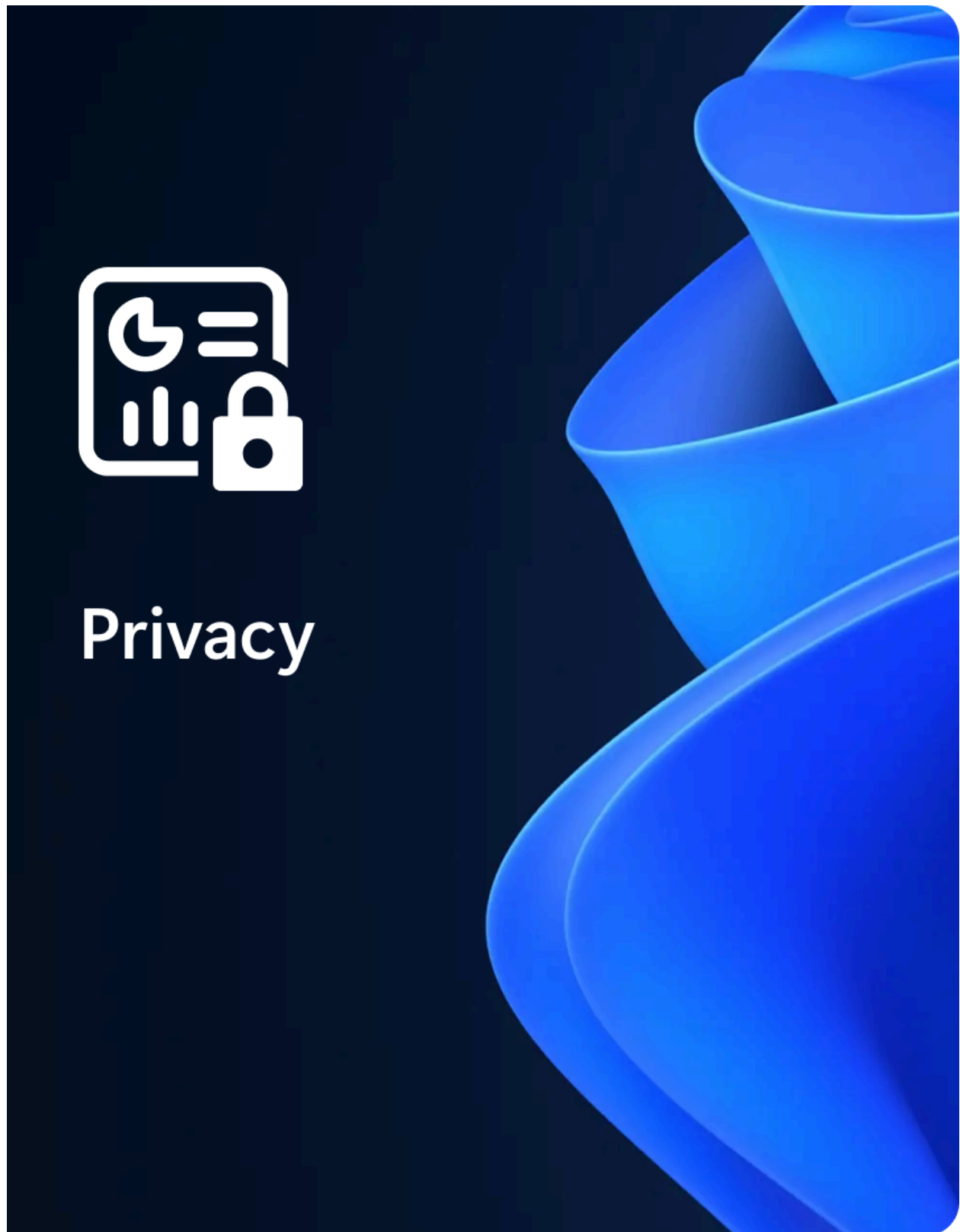
- Protect a greater number and variety of network resources from misuse
- Provision users to access resources in a manner that is consistent with organizational policies and the requirements of their jobs. Organizations can implement the principle of least-privilege access, which asserts that users should be granted access only to the data and operations they require to perform their jobs
- Update users' ability to access resources regularly, as an organization's policies change or as users' jobs change
- Support evolving workplace needs, including access from hybrid or remote locations, or from a rapidly expanding array of devices, including tablets and phones
- Identify and resolve access issues when legitimate users are unable to access resources that they need to perform their jobs

i Learn more

- [Access control](#)

Privacy

Article • 11/19/2024 • Applies to: [Windows 11](#)



Privacy is an important priority for individuals and organizations, and the rise of AI is bringing it into even sharper focus. Windows provides privacy controls that can be easily accessed in the Settings app or desktop system tray for speech, location, calendar, microphone, call history, and more. Users can also find more information and manage

privacy settings for Microsoft apps and services by signing into their [account dashboard](#).



Privacy controls

Article • 11/19/2024 • Applies to: [Windows 11](#)

Microsoft Privacy Dashboard

Customers can use the Microsoft Privacy Dashboard to view, export, and delete their information, giving them further transparency and control. They can also use the Microsoft Privacy Report to learn more about Windows data collection and how to manage it. For organizations, we provide a guide for Windows Privacy Compliance that includes more details on the available controls and transparency.

 **Learn more**

- [Microsoft Privacy Dashboard](#) 
- [Microsoft Privacy Report](#) 

Privacy transparency and controls

Prominent system tray icons show users when resources and apps like microphones and location are in use. A description of the app and its activity are presented in a simple tooltip that appears when you hover over an icon with your cursor. Apps can also make use of new Windows APIs to support Quick Mute functionality and more.

Privacy resource usage

Every Microsoft customer should be able to use our products secure in the knowledge that we protect their privacy, and give them the information and tools they need to easily make privacy decisions with confidence. From Settings, the app usage history feature provides users with a seven-day history of resource access for Location, Camera, Microphone, Phone Calls, Messaging, Contacts, Pictures, Videos, Music library, Screenshots, and other apps.

This information helps you determine if an app is behaving as expected so that you can change the app's access to resources as desired.

Windows diagnostic data processor configuration

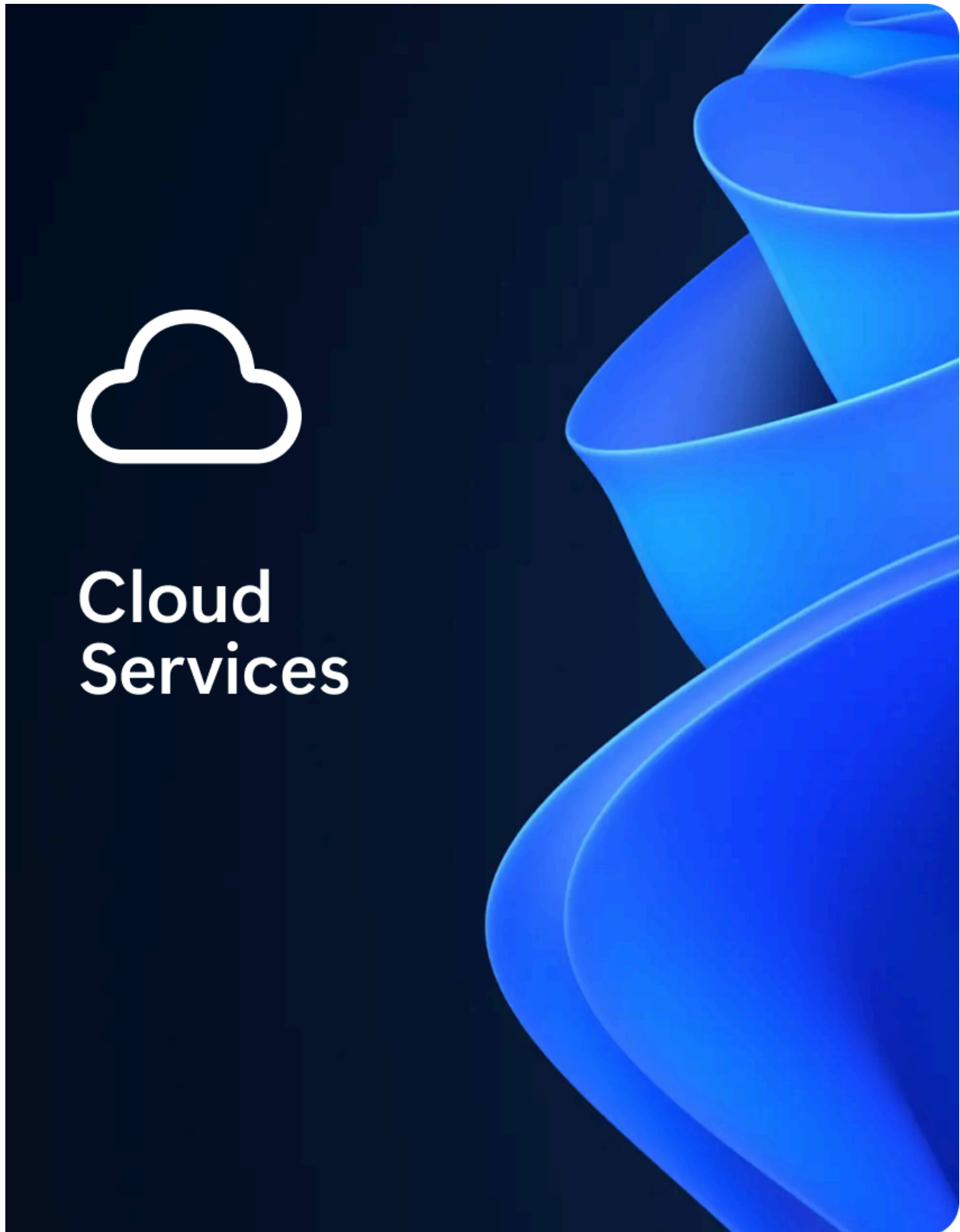
The Windows diagnostic data processor configuration enables the user to be the controller, as defined by the European Union General Data Protection Regulation (GDPR), for the Windows diagnostic data collected from Windows devices that meet the configuration requirements.

** Learn more**

- [Windows diagnostic data processor configuration](#)

Cloud services

Article • 11/19/2024 • Applies to: [Windows 11](#)



The workplace is constantly evolving, with many users working outside the office at least some of the time. While remote work and cloud services provide more flexibility, they also result in more endpoints and locations for organizations to worry about.

Windows 11, combined with Microsoft Entra ID for identity management, and cloud-based device management solutions like Microsoft Intune, can be the foundation of a *Zero Trust* security model that enables flexible workstyles while controlling access, safeguarding sensitive information, and mitigating threats.



Protect your work information

Article • 11/19/2024 • Applies to: [Windows 11](#)

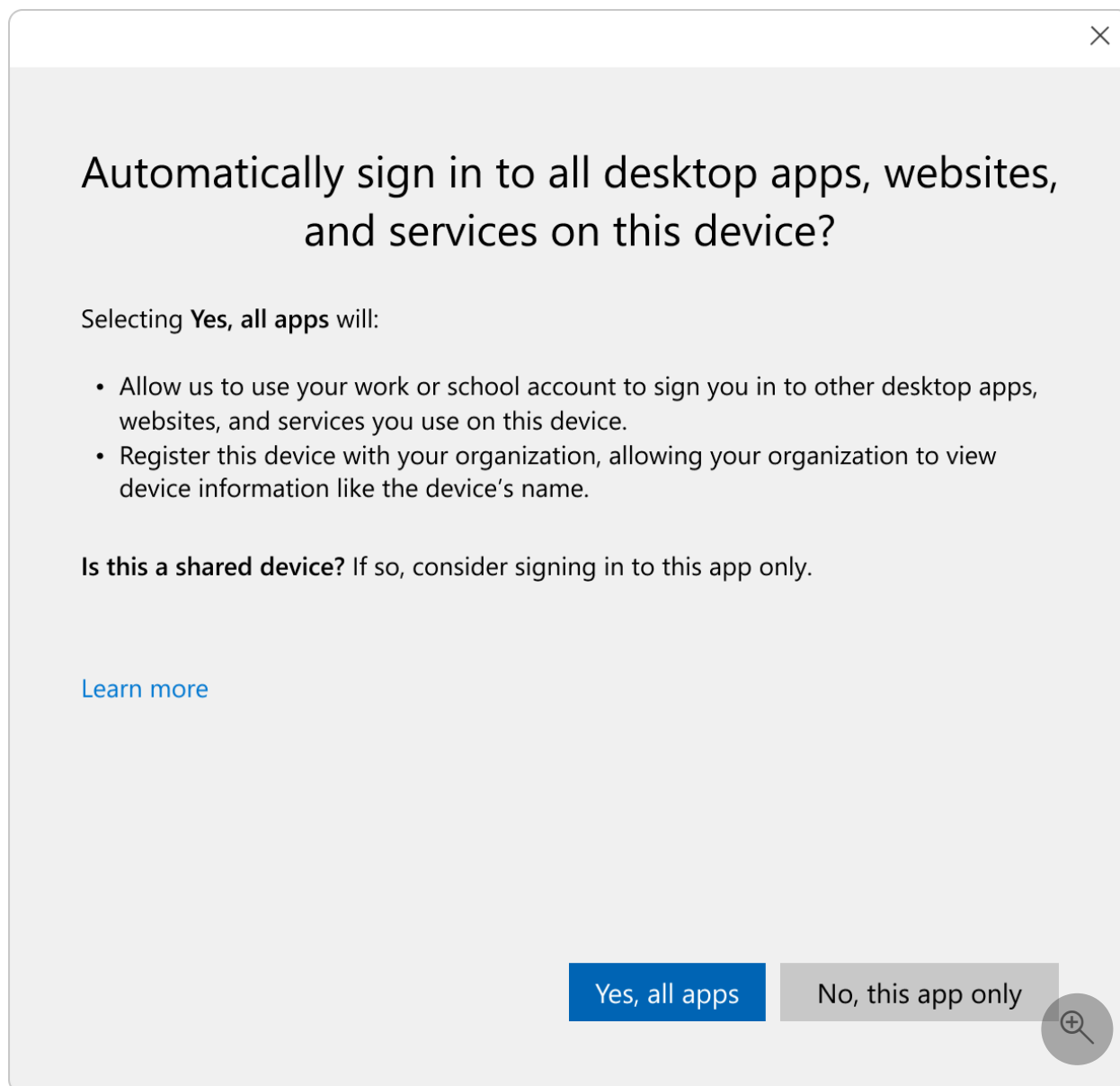


Microsoft Entra ID

Microsoft Entra ID is a comprehensive cloud-based identity management solution that helps enable secure access to applications, networks, and other resources and guard against threats. Microsoft Entra ID can also be used with Windows Autopilot for zero-touch provisioning of devices preconfigured with corporate security policies.

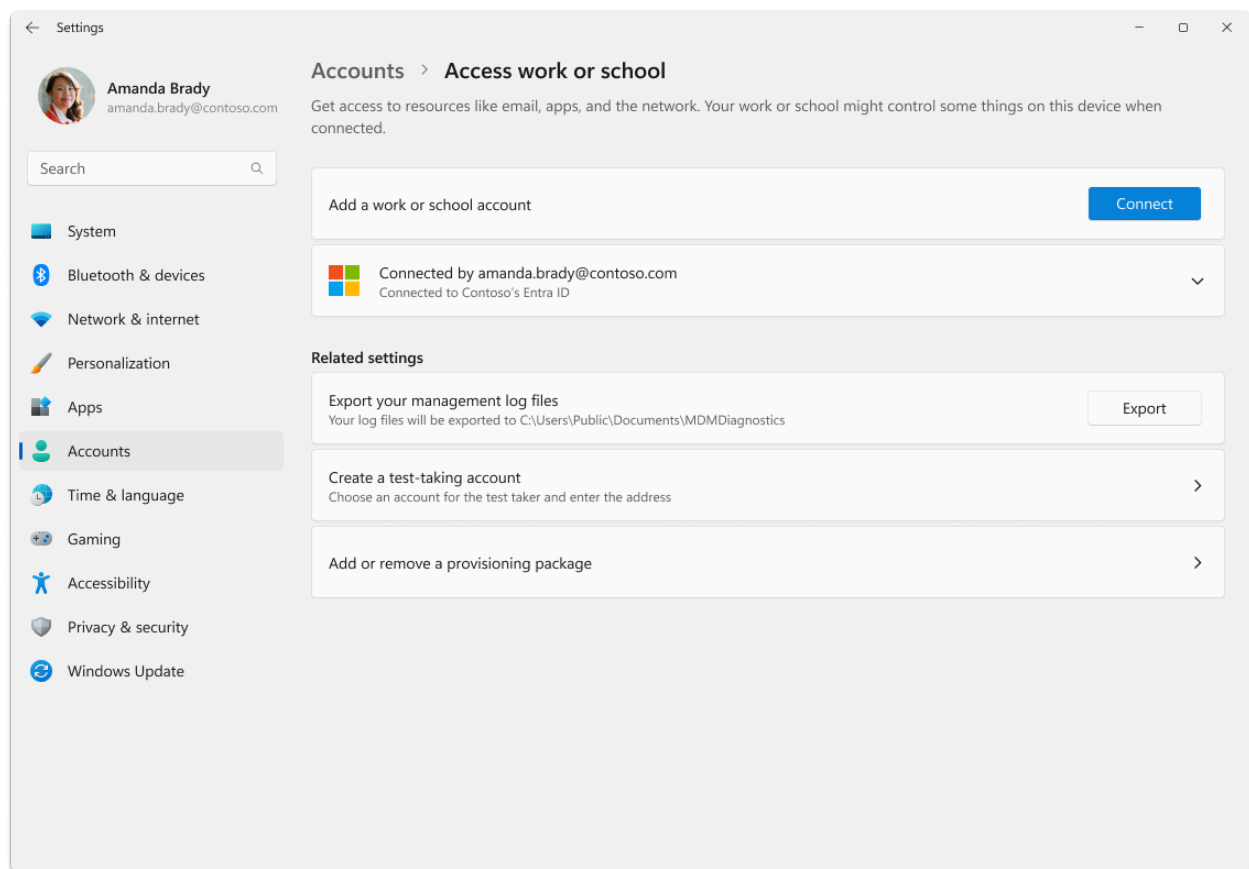
Organizations can deploy Microsoft Entra ID joined devices to enable access to both cloud and on-premises apps and resources. Access to resources can be controlled based on the Microsoft Entra ID account and Conditional Access policies applied to the device. For the most seamless and delightful end to end single sign-on (SSO) experience, we recommend users configure Windows Hello for Business during the out of box experience for easy passwordless sign-in to Entra ID .

For users wanting to connect to Microsoft Entra on their personal devices, they can do so by adding their work or school account to Windows. This action registers the user's personal device with Microsoft Entra ID, allowing IT admins to support users in bring your own device (BYOD) scenarios. Credentials are authenticated and bound to the joined device, and can't be copied to another device without explicit reverification.



To provide more security and control for IT and a seamless experience for users, Microsoft Entra ID works with apps and services, including on-premises software and thousands of software-as-a-service (SaaS) applications. Microsoft Entra ID protections include single sign-on, multifactor authentication, conditional access policies, identity protection, identity governance, and privileged identity management.

Windows 11 works with Microsoft Entra ID to provide secure access, identity management, and single sign-on to apps and services from anywhere. Windows has built-in settings to add work or school accounts by syncing the device configuration to an Active Directory domain or Microsoft Entra ID tenant.



When a device is Microsoft Entra ID joined and managed with Microsoft Intune^[4], it receives the following security benefits:

- Default managed user and device settings and policies
- Single sign-in to all Microsoft Online Services
- Full suite of authentication management capabilities using Windows Hello for Business
- Single sign-on (SSO) to enterprise and SaaS applications
- No use of consumer Microsoft account identity

Organizations and users can join or register their Windows devices with Microsoft Entra ID to get a seamless experience to both native and web applications. In addition, users can set up Windows Hello for Business or FIDO2 security keys with Microsoft Entra ID and benefit from greater security with passwordless authentication.

In combination with Microsoft Intune, Microsoft Entra ID offers powerful security control through Conditional Access to restrict access to organizational resources to healthy and compliant devices. Note that Microsoft Entra ID is only supported on Windows Pro and Enterprise editions.

Every Windows device has a built-in local administrator account that must be secured and protected to mitigate any Pass-the-Hash (PtH) and lateral traversal attacks. Many customers have been using our standalone, on-premises Windows Local Administrator Password Solution (LAPS) to manage their domain-joined Windows machines. We heard

from many customers that LAPS support was needed as they modernized their Windows environment to join directly to Microsoft Entra ID.

i Learn more

- [Microsoft Entra ID documentation](#)
- [Microsoft Entra plans and pricing](#)[↗]

Microsoft Entra Private Access

Microsoft Entra Private Access provides organizations the ability to manage and give users access to private or internal fully qualified domain names (FQDNs) and IP addresses. With Private Access, you can modernize how your organization's users access private apps and resources. Remote workers don't need to use a VPN to access these resources if they have the Global Secure Access Client installed. The client quietly and seamlessly connects them to the resources they need.

i Learn more

- [Microsoft Entra Private Access](#)

Microsoft Entra Internet Access

Microsoft Entra Internet Access provides an identity-centric Secure Web Gateway (SWG) solution for Software as a Service (SaaS) applications and other Internet traffic. It protects users, devices, and data from the Internet's wide threat landscape with best-in-class security controls and visibility through Traffic Logs.

ⓘ Note

Both Microsoft Entra Private Access and Microsoft Entra Internet Access requires Microsoft Entra ID and Microsoft Entra Joined devices for deployment. The two solutions use the Global Secure Access client for Windows, which secures and controls the features.

i Learn more

- [Microsoft Entra Internet Access](#)
- [Global Secure Access client for Windows](#)
- [Microsoft's Security Service Edge Solution Deployment Guide for Microsoft Entra Internet Access Proof of Concept](#)

Enterprise State Roaming

Available to any organization with a Microsoft Entra ID Premium^[4] license, Enterprise State Roaming provides users with a unified Windows Settings experience across their Windows devices and reduces the time needed for configuring a new device.

 **Learn more**

- [Enterprise State Roaming in Microsoft Entra ID](#)



Azure Attestation service

Remote attestation helps ensure that devices are compliant with security policies and are operating in a trusted state before they're allowed to access resources. Microsoft Intune^[4] integrates with Azure Attestation service to review Windows device health comprehensively and connect this information with Microsoft Entra ID^[4] Conditional Access.

Attestation policies are configured in the Azure Attestation service which can then:

- Verify the integrity of evidence provided by the Windows Attestation component by validating the signature and ensuring the Platform Configuration Registers (PCRs) match the values recomputed by replaying the measured boot log
- Verify that the TPM has a valid Attestation Identity Key issued by the authenticated TPM
- Verify that security features are in the expected states

Once this verification is complete, the attestation service returns a signed report with the security features state to the relying party - such as Microsoft Intune - to assess the trustworthiness of the platform relative to the admin-configured device compliance specifications. Conditional access is then granted or denied based on the device's compliance.

 **Learn more**

- [Azure Attestation overview](#)



Microsoft Defender for Endpoint

Microsoft Defender for Endpoint^[4] is an enterprise endpoint detection and response solution that helps security teams detect, disrupt, investigate, and respond to advanced

threats. Organizations can use the rich event data and attack insights Defender for Endpoint provides to investigate incidents.

Defender for Endpoint brings together the following elements to provide a more complete picture of security incidents:

- Endpoint behavioral sensors: Embedded in Windows, these sensors collect and process behavioral signals from the operating system and send this sensor data to your private, isolated cloud instance of Microsoft Defender for Endpoint
- With Automatic Attack Disruption uses AI, machine learning, and Microsoft Security Intelligence to analyze the entire attack and respond at the incident level, where it's able to contain a device, and/or a user which reduces the impact of attacks such as ransomware, human-operated attacks, and other advanced attacks.
- Cloud security analytics: Behavioral signals are translated into insights, detections, and recommended responses to advanced threats. These analytics leverage big data, device learning, and unique Microsoft optics across the Windows ecosystem, enterprise cloud products such as Microsoft 365^[4], and online assets
- Threat intelligence: Microsoft processes over 43 trillion security signals every 24 hours, yielding a deep and broad view into the evolving threat landscape. Combined with our global team of security experts and cutting-edge artificial intelligence and machine learning, we can see threats that others miss. This threat intelligence helps provide unparalleled protection for our customers. The protections built into our platforms and products blocked attacks that include 31 billion identity threats and 32 billion email threats
- Rich response capabilities: Defender for Endpoint empowers SecOps teams to isolate, remediate, and remote into machines to further investigate and stop active threats in their environment, as well as block files, network destinations, and create alerts for them. In addition, Automated Investigation and Remediation can help reduce the load on the SOC by automatically performing otherwise manual steps towards remediation and providing detailed investigation outcomes

Defender for Endpoint is also part of Microsoft Defender XDR, our end-to-end, cloud-native extended detection and response (XDR) solution that combines best-of-breed endpoint, email, and identity security products. It enables organizations to prevent, detect, investigate, and remediate attacks by delivering deep visibility, granular context, and actionable insights generated from raw signals harnessed across the Microsoft 365 environment and other platforms, all synthesized into a single dashboard. This solution offers tremendous value to organizations of any size, especially those that are looking to break away from the added complexity of multiple point solutions, keeping them protected from sophisticated attacks and saving IT and security teams' time and resources.

Learn more

- [Microsoft Defender for Endpoint](#)
- [Microsoft 365 Defender](#)

Cloud-native device management

Microsoft recommends cloud-based device management so that IT professionals can manage company security policies and business applications without compromising user privacy on corporate or employee-owned devices. With cloud-native device management solutions like Microsoft Intune^[4], IT can manage Windows 11 using industry standard protocols. To simplify setup for users, management features are built directly into Windows, eliminating the need for a separate device management client.

Windows 11 built-in management features include:

- The enrollment client, which enrolls and configures the device to securely communicate with the enterprise device management server
- The management client, which periodically synchronizes with the management server to check for updates and apply the latest policies set by IT

Learn more

- [Mobile device management overview](#)

Remote wipe

When a device is lost or stolen, IT administrators might want to remotely wipe data stored in memory and hard disks. A helpdesk agent might also want to reset devices to fix issues encountered by remote workers. A remote wipe can also be used to prepare a previously used device for a new user.

Windows 11 supports the Remote Wipe configuration service provider (CSP) so that device management solutions can remotely initiate any of the following operations:

- Reset the device and remove user accounts and data
- Reset the device and clean the drive
- Reset the device but persist user accounts and data

Learn more

- [Remote wipe CSP](#)



Microsoft Intune

Microsoft Intune^[4] is a comprehensive cloud-native endpoint management solution that helps secure, deploy, and manage users, apps, and devices. Intune brings together technologies like Microsoft Configuration Manager and Windows Autopilot to simplify provisioning, configuration management, and software updates across the organization.

Intune works with Microsoft Entra ID to manage security features and processes, including multifactor authentication and conditional access.

Organizations can cut costs while securing and managing remote devices through the cloud in compliance with company policies^[11]. For example, organizations can save time and money by provisioning preconfigured devices to remote employees using Windows Autopilot.

Windows 11 enables IT professionals to move to the cloud while consistently enforcing security policies. Windows 11 provides expanded support for group policy administrative templates (ADMX-backed policies) in cloud-native device management solutions like Microsoft Intune, enabling IT professionals to easily apply the same security policies to both on-premises and remote devices.

Customers have asked for App Control for Business (previously called *Windows Defender Application Control*) to support manage installer for a long time. Now it's possible to enable allowlisting of Win32 apps to proactively reduce the number of malware infections.

Learn more

- [What is Microsoft Intune](#)

Windows enrollment attestation

When a device enrolls into device management, the administrator expects it to receive the appropriate policies to secure and manage the PC. However, in some cases, malicious actors can remove enrollment certificates and use them on unmanaged PCs, making them appear enrolled but without the intended security and management policies.

With Windows enrollment attestation, Microsoft Entra and Microsoft Intune certificates are bound to a device using the Trusted Platform Module (TPM). This ensures that the certificates can't be transferred from one device to another, maintaining the integrity of the enrollment process.

Learn more

- [Windows enrollment attestation](#)

Microsoft Cloud PKI

Microsoft Cloud PKI is a cloud-based service included in the Microsoft Intune Suite^[4] that simplifies and automates the management of a Public Key Infrastructure (PKI) for organizations. It eliminates the need for on-premises servers, hardware, and connectors, making it easier to set up and manage a PKI compared to, for instance, Microsoft Active Directory Certificate Services (AD CS) combined with the Certificate Connector for Microsoft Intune.

Key features include:

- Certificate lifecycle management: automates the lifecycle of certificates, including issuance, renewal, and revocation, for all devices managed by Intune
- Multi-platform support: supports certificate management for Windows, iOS/iPadOS, macOS, and Android devices
- Enhanced security: enables certificate-based authentication for Wi-Fi, VPN, and other scenarios, improving security over traditional password-based methods. All certificate requests leverage Simple Certificate Enrollment Protocol (SCEP), making sure that the private key never leaves the requesting client
- Simplified management: provides easy management of certification authorities (CAs), registration authorities (RAs), certificate revocation lists (CRLs), monitoring, and reporting

With Microsoft Cloud PKI, organizations can accelerate their digital transformation and achieve a fully managed cloud PKI service with minimal effort.

Learn more

- [Overview of Microsoft Cloud PKI for Microsoft Intune](#)

Endpoint Privilege Management (EPM)

Intune Endpoint Privilege Management supports organizations' Zero Trust journeys by helping them achieve a broad user base running with least privilege, while still permitting users to run elevated tasks allowed by the organization to remain productive.

Learn more

- [Endpoint Privilege Management](#)

Mobile application management (MAM)

With Intune, organizations can also extend MAM App Config, MAM App Protection, and App Protection Conditional Access capabilities to Windows. This enables people to access protected organizational content without having the device managed by IT. The first application to support MAM for Windows is Microsoft Edge.

 [Learn more](#)

- [Data protection for Windows MAM](#)

Security baselines

Every organization faces security threats. However, different organizations can be concerned with different types of security threats. For example, an e-commerce company might focus on protecting its internet-facing web apps, while a hospital on confidential patient information. The one thing that all organizations have in common is a need to keep their apps and devices secure. These devices must be compliant with the security standards (or security baselines) defined by the organization.

A security baseline is a group of Microsoft-recommended configuration settings that explains their security implications. These settings are based on feedback from Microsoft security engineering teams, product groups, partners, and customers.

 [Learn more](#)

- [Security baselines](#)

Security baseline for cloud-based device management solutions

Windows 11 can be configured with Microsoft's security baseline, designed for cloud-based device management solutions like Microsoft Intune^[4]. These security baselines function similarly to group policy-based ones and can be easily integrated into existing device management tools.

The security baseline includes policies for:

- Microsoft inbox security technologies such as BitLocker, Microsoft Defender SmartScreen, Virtualization-based security, Exploit Guard, Microsoft Defender Antivirus, and Windows Firewall
- Restricting remote access to devices
- Setting credential requirements for passwords and PINs

- Restricting the use of legacy technology

Learn more

- [Intune security baseline overview](#)
- [List of the settings in the Windows security baseline in Intune](#)

Windows Local Administrator Password Solution (LAPS)

Windows Local Administrator Password Solution (LAPS) is a feature that automatically manages and backs up the password of a local administrator account on Microsoft Entra joined and Active Directory-joined devices. It helps enhance security by regularly rotating and managing local administrator account passwords, protecting against pass-the-hash and lateral-traversal attacks.

Windows LAPS can be configured via group policy or with a device management solution like Microsoft Intune^[4].

New in Windows 11, version 24H2

Several enhancements have been made to improve manageability and security. Administrators can now configure LAPS to automatically create managed local accounts, integrating with existing policies to enhance security and efficiency. Policy settings have been updated to generate more readable passwords by ignoring certain characters and to support the generation of readable passphrases, with options to choose from three separate word source list and control passphrase length. Additionally, LAPS can detect when a computer rolls back to a previous image, ensuring password consistency between the computer and Active Directory.

Learn more

- [Windows LAPS overview](#)

Windows Autopilot

Traditionally, IT professionals spend significant time building and customizing images that will later be deployed to devices. If you're purchasing new devices or managing device refresh cycles, you can use Windows Autopilot to set up and preconfigure new devices, getting them ready for productive use. Autopilot helps you ensure your devices are delivered locked down and compliant with corporate security policies. The solution can also be used to reset, repurpose, and recover devices with zero touch by your IT

team and no infrastructure to manage, enhancing efficiency with a process that's both easy and simple.

With Windows Autopilot, there's no need to reimage or manually set-up devices before giving them to the users. Your hardware vendor can ship them, ready to go, directly to the users. From a user perspective, they turn on their device, go online, and Windows Autopilot delivers apps and settings.

Windows Autopilot enables you to:

- Automatically join devices to Microsoft Entra ID or Active Directory via Microsoft Entra hybrid join
- Autoenroll devices into a device management solution like Microsoft Intune^[4] (requires a Microsoft Entra ID Premium subscription for configuration)
- Create and autoassignment of devices to configuration groups based on a device's profile
- Customize of the out-of-box experience (OOBE) content specific to your organization

Existing devices can also be quickly prepared for a new user with Windows Autopilot Reset. The reset capability is also useful in break/fix scenarios to quickly bring a device back to a business-ready state.

Learn more

- [Windows Autopilot](#)
- [Windows Autopilot Reset](#)

Windows Update for Business

Windows Update for Business empowers IT administrators to ensure that their organization's Windows client devices are consistently up to date with the latest security updates and features. By directly connecting these systems to the Windows Update service, administrators can maintain a high level of security and functionality.

Administrators can utilize group policy or a device management solution like Microsoft Intune^[4], to configure Windows Update for Business settings. These settings control the timing and manner in which updates are applied, allowing for thorough reliability and performance testing on a subset of devices before deploying updates across the entire organization.

This approach not only provides control over the update process but also ensures a seamless and positive update experience for all users within the organization. By using

Windows Update for Business, organizations can achieve a more secure and efficient operational environment.

i Learn more

- [Windows Update for Business documentation](#)

Windows Autopatch

Cybercriminals commonly exploit obsolete or unpatched software to infiltrate networks. It's essential to maintain current updates to seal security gaps. Windows Autopatch is a cloud service that automates Windows, Microsoft 365 Apps for enterprise, Microsoft Edge, and Microsoft Teams updates to improve security and productivity across your organization. Autopatch helps you minimize the involvement of your scarce IT resources in the planning and deployment of updates so your IT Admins can focus on other activities and tasks.

There's a lot more to learn about Windows Autopatch: this [Forrester Consulting Total Economic Impact™ Study](#) [↗](#) commissioned by Microsoft, features insights from customers who deployed Windows Autopatch and its impact on their organizations. You can also find out more information about new Autopatch features and the future of the service in the regularly published Windows IT Pro Blog and Windows Autopatch community.

i Learn more

- [Windows Autopatch documentation](#)
- [Windows updates API overview](#)
- [Windows IT Pro Blog](#) [↗](#)
- [Windows Autopatch community](#) [↗](#)



Windows Hotpatch

Windows Hotpatch is a feature designed to enhance security and minimize disruptions. With Windows Hotpatch, organizations can apply critical security updates without requiring a system restart, reducing the time to adopt a security update by 60% from the moment the update is offered. Hotpatch updates streamline the installation process, enhance compliance efficiency, and provide a per-policy level view of update statuses for all devices.

By utilizing hotpatching through Windows Autopatch, the number of system restarts for Windows updates can be reduced from 12 times a year to just 4, ensuring consistent

protection and uninterrupted productivity. This means less downtime, a streamlined experience for users, and a reduction in security risks. This technology, proven in the Azure Server environment, is now expanding to Windows 11, offering immediate security from day one without the need for a restart.

 **Learn more**

- [Windows Autopatch documentation](#)



OneDrive for work or school

OneDrive for work or school is a cloud storage service that allows users to store, share, and collaborate on files. It's a part of Microsoft 365 and is designed to help organizations protect their data and comply with regulations. OneDrive for work or school is protected both in transit and at rest.

When data transits either into the service from clients or between datacenters, it's protected using transport layer security (TLS) encryption. OneDrive only permits secure access.

Authenticated connections aren't allowed over HTTP and instead redirect to HTTPS.

There are several ways that OneDrive for work or school is protected at rest:

- **Physical protection:** Microsoft understands the importance of protecting customer data and is committed to securing the datacenters that contain it. Microsoft datacenters are designed, built, and operated to strictly limit physical access to the areas where customer data is stored. Physical security at datacenters is in alignment with the defense-in-depth principle. Multiple security measures are implemented to reduce the risk of unauthorized users accessing data and other datacenter resources. Learn more [here](#).
- **Network protection:** The networks and identities are isolated from the corporate network. Firewalls limit traffic into the environment from unauthorized locations
- **Application security:** Engineers who build features follow the security development lifecycle. Automated and manual analyses help identify possible vulnerabilities. The [Microsoft Security Response Center](#)  helps triage incoming vulnerability reports and evaluate mitigations. Through the [Microsoft Cloud Bug Bounty Terms](#) , people across the world can earn money by reporting vulnerabilities
- **Content protection:** Each file is encrypted at rest with a unique AES-256 key. These unique keys are encrypted with a set of master keys that are stored in Azure Key Vault

 **Learn more**

- [How OneDrive safeguards data in the cloud](#) 



Universal Print

Universal Print eliminates the need for on-premises print servers. It also eliminates the need for print drivers from the users' Windows devices and makes the devices secure, reducing the malware attacks that typically exploit vulnerabilities in driver model. It enables Universal Print-ready printers (with native support) to connect directly to the Microsoft Cloud. All major printer OEMs have these [models](#). It also supports existing printers by using the connector software that comes with Universal Print.

Unlike traditional print solutions that rely on Windows print servers, Universal Print is a Microsoft-hosted cloud subscription service that supports a Zero Trust security model when using the Universal Print-ready printers. Customers can enable network isolation of printers, including the Universal Print connector software, from the rest of the organization's resources. Users and their devices don't need to be on the same local network as the printers or the Universal Print connector.

Universal Print supports Zero Trust security by requiring that:

- Each connection and API call to Universal Print cloud service requires authentication validated by Microsoft Entra ID^[4]. A hacker would have to have knowledge of the right credentials to successfully connect to the Universal Print service
- Every connection established by the user's device (client), the printer, or another cloud service to the Universal Print cloud service uses SSL with TLS 1.2 protection. This protects network snooping of traffic to gain access to sensitive data
- Each printer registered with Universal Print is created as a device object in the customer's Microsoft Entra ID tenant and issued its own device certificate. Every connection from the printer is authenticated using this certificate. The printer can access only its own data and no other device's data
- Applications can connect to Universal Print using either user, device, or application authentication. To ensure data security, it's highly recommended that only cloud applications use application authentication
- Each acting application must register with Microsoft Entra ID and specify the set of permission scopes it requires. Microsoft's own acting applications - for example, the Universal Print connector - are registered with the Microsoft Entra ID service. Customer administrators need to provide their consent to the required permission scopes as part of onboarding the application to their tenant
- Each authentication with Microsoft Entra ID from an acting application can't extend the permission scope as defined by the acting client app. This prevents the app

from requesting additional permissions if the app is breached

Additionally, Windows 11 includes device management support to simplify printer setup for users. With support from Microsoft Intune^[4], admins can now configure policy settings to provision specific printers onto the user's Windows devices.

Universal Print stores the print data in cloud securely in Office Storage, the same storage used by other Microsoft 365 products.

More information about handling of Microsoft 365 data (this includes Universal Print data) can be found [here](#).

The Universal Print secure release platform ensures user privacy, secures organizational data, and reduces print wastage. It eliminates the need for people to rush to a shared printer as soon as they send a print job to ensure that no one sees the private or confidential content. Sometimes, printed documents are picked up by another person or not picked up at all and discarded. Detailed support and configuration information can be found [here](#).

Universal Print supports Administrative Units in Microsoft Entra ID to enable the assignments of a *Printer Administrator* role to specific teams in the organization. The assigned team can configure only the printers that are part of the same Administrative Unit.

For customers who want to stay on print servers, we recommend using the Microsoft IPP Print driver. For features beyond what's covered in the standard IPP driver, use Print Support Applications (PSA) for Windows from the respective printer OEM.

Learn more

- [Universal Print](#) 
- [Data handling in Universal Print](#)
- [Delegate Printer Administration with Administrative Units](#)
- [Print support app design guide](#)

Protect your personal information

Article • 11/19/2024 • Applies to: [Windows 11](#)



Microsoft account

Your Microsoft account (MSA) provides seamless access to Microsoft products and services with just one sign-in, allowing you to manage everything in one place. You can easily keep track of your subscriptions and order history, update your privacy and security settings, monitor the health and safety of your devices, and earn rewards. Your information stays with you in the cloud, accessible across devices and operating systems, including iOS and Android.

You can even go passwordless with your Microsoft account by removing the password from your MSA:

- Use Windows Hello to eliminate the password sign-in method for an even more secure experience
- Use the Microsoft Authenticator app on your Android or iOS device

Learn more

- [What is a Microsoft account?](#) 
- [Go passwordless with your Microsoft account](#) 

Find my device

When location services and *Find my device* settings are turned on, basic system services like time zone and Find my device are allowed to use the device's location. Find my device can be used to help recover lost or stolen Windows devices, reducing the security threats that rely on physical access.

Learn more

- [How to set up, find, and lock a lost Windows device using a Microsoft account](#) 

OneDrive for personal

Microsoft OneDrive for personal^[10] offers enhanced security, backup, and restore options for important personal files. Users can access their data from anywhere, since their files are stored and protected in the cloud. OneDrive provides an excellent solution for backing up folders, ensuring that:

- If a device is lost or stolen, users can quickly recover all their important files from the cloud
- If a user is targeted by a ransomware attack, OneDrive enables recovery. With configured backups, users have more options to mitigate and recover from such attacks

Learn more

- [Get started with OneDrive](#) 
- [How to recover from a ransomware attack using Microsoft 365](#)
- [How to restore from OneDrive](#) 

Personal Vault

Personal Vault offers robust protection for the most important or sensitive files, without sacrificing the convenience of anywhere access. Secure digital copies of crucial documents in Personal Vault, where they're protected by identity verification and are easily accessible across devices.

Once the Personal Vault is configured, users can access it using a strong authentication method or a second step of identity verification. The second steps of verification include fingerprint, face recognition, PIN, or a code sent via email or text.

Learn more

- [Protect your OneDrive files in Personal Vault](#) 

Security foundation in Windows 11

Article • 11/22/2024 • Applies to: [Windows 11](#)



Microsoft is committed to continuously investing in improving the development process, building highly secure-by-design software, and addressing security compliance requirements. Security and privacy considerations informed by offensive research are built into each phase of our product design and software development process.

Microsoft's security foundation includes not only our development and certification processes, but also our end-to-end supply chain. The comprehensive Windows 11 security foundation also reflects our deep commitment to principles of security by design and security by default.



Secure Future Initiative and offensive research

Article • 11/19/2024 • Applies to: [Windows 11](#)

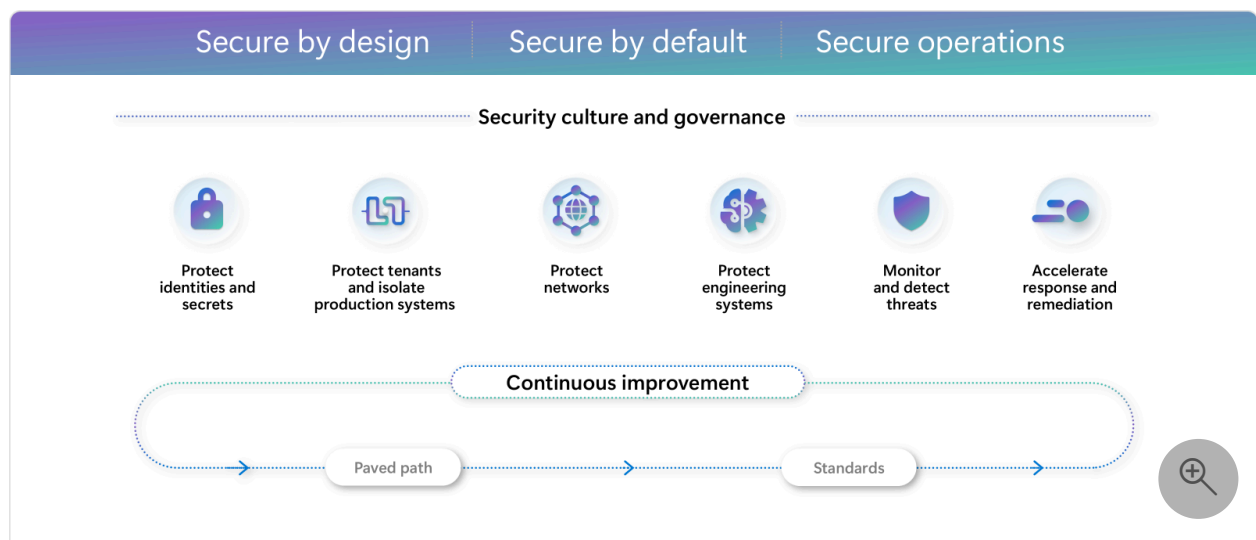


Secure Future Initiative (SFI)

Launched in November 2023, the Microsoft Secure Future Initiative (SFI) is a multiyear commitment dedicated to advancing the way we design, build, test, and operate our technology. Our goal is to ensure that our solutions meet the highest possible standards for security.

The increasing scale and high stakes of cyberattacks prompted the launch of SFI. This program brings together every part of Microsoft to enhance cybersecurity protection across our company and products. We carefully considered our internal observations and feedback from customers, governments, and partners to identify the greatest opportunities to impact the future of security.

To maintain accountability and keep our customers, partners, and the security community informed, Microsoft provides regular updates on the progress of SFI.



[Learn more](#)

- [Microsoft Secure Future Initiative](#)
- [September 2024 progress update on SFI](#)

Microsoft Security Development Lifecycle (SDL)

The Microsoft Security Development Lifecycle (SDL) introduces security best practices, tools, and processes throughout all phases of engineering and development.

OneFuzz service

A range of tools and techniques - such as threat modeling, static analysis, fuzz testing, and code quality checks - enable continued security value to be embedded into Windows by every engineer on the team from day one. Through the SDL practices, Microsoft engineers are continuously provided with actionable and up-to-date methods to improve development workflows and overall product security before the code is released.

Microsoft Offensive Research and Security Engineering

Microsoft Offensive Research and Security Engineering (MORSE) performs targeted design reviews, audits, and deep penetration testing of Windows features using Microsoft's open-source OneFuzz platform as part of their development and testing cycle.

 [Learn more](#)

- [MORSE security team takes proactive approach to finding bugs](#) 
- [MORSE Blog](#) 

Windows Insider and Microsoft Bug Bounty Programs

As part of our secure development process, the Windows Insider Preview Program invites eligible researchers across the globe to find and submit vulnerabilities that reproduce in the latest Windows Insider Preview (WIP) Dev Channel.

The goal of the Windows Insider Preview Program is to uncover significant vulnerabilities that have a direct and demonstrable impact on the security of customers using the latest version of Windows.

Through this collaboration with researchers across the globe, our teams identify critical vulnerabilities and quickly fix the issues before releasing our final Windows.

 Learn more

- [Windows Insider Program](#)
- [Microsoft Bug Bounty Programs](#) 

Certification

Article • 11/19/2024 • Applies to: [Windows 11](#)



Microsoft is committed to supporting product security standards and certifications, including FIPS 140 and Common Criteria, as an external validation of security assurance.

Federal Information Processing Standard (FIPS)

The Federal Information Processing Standard (FIPS) Publication 140 is a U.S. government standard that specifies the minimum security requirements for cryptographic modules in IT products. Microsoft is dedicated to adhering to the requirements in the FIPS 140 standard, consistently validating its cryptographic modules against FIPS 140 since the standard's inception. Microsoft products, including Windows 11, Windows 10, Windows Server, and many cloud services, use these cryptographic modules.

Learn more

- [Windows FIPS 140 validation](#)

Common Criteria (CC)

Common Criteria (CC) is an international standard currently maintained by national governments who participate in the Common Criteria Recognition Arrangement. Common Criteria defines a common taxonomy for security functional requirements, security assurance requirements, and an evaluation methodology used to ensure products undergoing evaluation satisfy the functional and assurance requirements.

Microsoft ensures that products incorporate the features and functions required by relevant Common Criteria Protection Profiles and completes Common Criteria certifications of Microsoft Windows products.

Learn more

- [Common Criteria certifications](#)

Secure supply chain

Article • 11/19/2024 • Applies to: [Windows 11](#)



The end-to-end Windows 11 supply chain is complex. It extends from the entire development process, to components such as chips, firmware, drivers, operating system, and apps from other organizations, manufacturing, and security updates. Microsoft invests significantly in Windows 11 supply chain security, and the security of features and components. In 2021, the United States issued an executive order on enhancing the nation's cybersecurity. The executive order, along with various attacks like SolarWinds and WannaCry, elevated the urgency and importance of ensuring a secure supply chain.

Microsoft requires the Windows 11 supply chain to comply with controls including:

- Identity management and user access control
 - Access control
 - Principles of least privilege
 - Role-based access control (role-based access control)
 - Segregation of duties
 - MFAs
 - Account management
 - Physical access control
- Information security
 - Information handling
 - Cryptography
 - Vulnerability scanning
 - Encryption
 - Integrity and attestation
 - Confidentiality
- Operational controls
 - Code of repo ownership
 - Config & change management
 - Asset ownership
 - Manufacturing standards
- Security monitoring & event logging
 - Network
 - Host
 - Application
 - Services

- DevOps
- Manufacturing security
- Physical security monitoring
- Supplier security control
 - Supplier Security and Privacy Assurance (SSPA)
 - Supplier screening
 - Supplier inventory
- Logistics security control
 - Receiving
 - Shipping
 - Warehouse & storage
 - Logistics management

Software bill of materials (SBOM)

In the Windows ecosystem, ensuring the integrity and authenticity of software components is paramount. To achieve this, we utilize Software Bill of Materials (SBOMs) and COSE (CBOR Object Signing and Encryption) sign all evidence. SBOMs provide a comprehensive inventory of software components, including their dependencies and associated metadata. Transparency is crucial for vulnerability management and compliance with security standards.

The COSE signing process enhances the trustworthiness of SBOMs by providing cryptographic signatures that verify the integrity and authenticity of the SBOM content. The CoseSignTool, a platform-agnostic command line application, is employed to apply and verify these digital signatures. This tool ensures that all SBOMs and other build evidence are signed and validated, maintaining a high level of security within the software supply chain.

By integrating SBOMs and COSE signing evidence, we offer stakeholders visibility into the components they use, ensuring that all software artifacts are trustworthy and secure. This approach aligns with our commitment to end-to-end supply chain security, providing a robust framework for managing and verifying software components across the Windows ecosystem.

Learn more

- [SBOM tool](#) 
- [Code Sign Tool](#) 

Windows Software Development Kit (SDK)

Developers can design highly secure applications that benefit from the latest Windows 11 safeguards using the Windows SDK. The SDK provides a unified set of APIs and tools for developing secure desktop apps for Windows 11 and Windows 10. To help create apps that are up to date and protected, the SDK follows the same security standards, protocols, and compliance as the core Windows operating system.

** Learn more**

- [Windows application development - best practices](#)
- [Windows SDK samples on GitHub](#) 

Conclusion

Article • 11/19/2024 • Applies to: [Windows 11](#)

We will continue to innovate with security by design and security by default at the heart of every new Windows 11 PC and Windows 11 IoT device. This commitment ensures that our products not only meet, but exceed, the security expectations of our customers by providing robust protection against modern cyber threats while maintaining ease-of-use and performance. By integrating advanced security measures from the ground up, we aim to create a safer digital environment for everyone.



What's new

New:

- [Administrator protection](#)
- [Config Refresh](#)
- [Rust for Windows](#)
- [Trusted Signing](#)
- [VBS key protection](#)
- [Virtualization-based security enclaves](#)
- [Win32 app isolation](#)
- [Windows Hotpatch](#)
- [Windows protected print](#)

Enhanced:

- [BitLocker](#)
- [Credential Guard](#)
- [Device encryption](#)
- [Local Security Authority \(LSA\) protection](#)
- [Passkeys](#)
- [Personal data encryption](#)
- [Secured kernel](#)
- [Server Message Block file services](#)
- [Windows Hello PIN](#)
- [Windows Firewall](#)
- [Windows Local Administrator Password Solution \(LAPS\)](#)
- [Windows Subsystem for Linux \(WSL\)](#)

Document revision history

 Expand table

Date	Summary
November 2021	Link updates and formatting.
February 2022	Revisions to Hardware root-of-trust, Virus and threat protection, and Windows Hello for Business content.
April 2022	Added Upcoming features section.
September 2022	Updates with Windows 11, version 22H2, features and enhancements.
April 2023	Minor edits and updates to edition availability.
September 2023	Updates with Windows 11, version 23H2, features and enhancements.
May 2024	Move from PDF format to web format.
November 2024	Updates with Windows 11, version 24H2, features and enhancements.

Endnotes

 Expand table

Details	
1	Microsoft digital defense report, CISO executive summary, October 2023 ↗ .
2	Windows 11 Survey Report. Techaisle, September 2024. Windows 11 results are in comparison with Windows 10 devices.
3	Requires developer enablement.
4	Sold separately.
5	The Passkey can be saved locally to the Windows device and authenticated via Windows Hello or Windows Hello for Business. Hardware dependent.
6	Commissioned study delivered by Forrester Consulting "The Total Economic Impact™ of Windows 11 Pro Devices", December 2022. Note, quantified benefits reflect results over three years combined into a single composite organization that generates \$1 billion in annual revenue, has 2,000 employees, refreshes hardware on a four-year cycle, and migrates the entirety of its workforce to Windows 11 devices.
7	Feature or functionality delivered using servicing technology ↗ .
8	Email encryption is supported on products such as Microsoft Exchange Server and Microsoft Exchange Online.
9	Hardware dependent.
10	All users with a Microsoft account get 5GB of OneDrive storage free, and all Microsoft 365 subscriptions include 1TB of OneDrive storage. Additional OneDrive storage is sold separately.
11	The Total Economic Impact™ of Windows Pro Device, Forrester study commissioned by Microsoft, June 2020.

The information contained in this document represents the current view of Microsoft Corporation on the issues discussed as of the date of publication. Because Microsoft must respond to changing market conditions, it should not be interpreted to be a commitment on the part of Microsoft, and Microsoft cannot guarantee the accuracy of any information presented after the date of publication.

This paper is for informational purposes only. Microsoft makes no warranties, express or implied, in this document.

Complying with all applicable copyright laws is the responsibility of the user. Without limiting the rights under copyright, no part of this document may be reproduced, stored in, or introduced into a retrieval system, or transmitted in any form or by any means (electronic, mechanical, photocopying, recording, or

otherwise), or for any purpose, without the express written permission of Microsoft Corporation.

Microsoft may have patents, patent applications, trademarks, copyrights, or other intellectual property rights covering subject matter in this document. Except as expressly provided in any written license agreement from Microsoft, the furnishing of this document does not give you any license to these patents, trademarks, copyrights, or other intellectual property.

© 2024 Microsoft Corporation. All rights reserved.

Microsoft, list Microsoft trademarks used in your white paper alphabetically are either registered trademarks or trademarks of Microsoft Corporation in the United States and/or other countries.

The names of actual companies and products mentioned herein may be the trademarks of their respective owners.

Part No. November 2024

Features index

Article • 11/20/2024 • Applies to: [Windows 11](#)

[5G and eSIM](#)

[Access management and control](#)

[Account lockout policies](#)

[Administrator protection](#)

[App containers](#)

[App Control for Business](#)

[Attack surface reduction rules](#)

[Azure Attestation service](#)

[BitLocker To Go](#)

[BitLocker](#)

[Bluetooth protection](#)

[Certificates](#)

[Cloud-native device management](#)

[Code signing and integrity](#)

[Common Criteria \(CC\)](#)

[Config Refresh](#)

[Controlled folder access](#)

[Credential Guard](#)

[Cryptography](#)

[Device Encryption](#)

[Device Health Attestation](#)

[Domain Name System \(DNS\) security](#)

[Email encryption](#)

[Encrypted hard drive](#)

[Enhanced phishing protection in Microsoft Defender SmartScreen](#)

[Enhanced Sign-in Security \(ESS\)](#)

[Exploit Protection](#)

[Federal Information Processing Standard \(FIPS\)](#)

[Federated sign-in](#)

[FIDO2](#)

[Find my device](#)

[Kernel direct memory access \(DMA\) protection](#)

[Kiosk mode](#)

[Local Security Authority \(LSA\) protection](#)

[Microsoft account](#)

[Microsoft Authenticator](#)

[Microsoft Cloud PKI](#)

Microsoft Defender Antivirus
Microsoft Defender for Endpoint
Microsoft Defender SmartScreen
Microsoft Entra ID
Microsoft Intune
Microsoft Offensive Research and Security Engineering
Microsoft Pluton security processor
Microsoft Privacy Dashboard
Microsoft Security Development Lifecycle (SDL)
Microsoft vulnerable driver blocklist
Network protection
OneDrive for personal
OneDrive for work or school
OneFuzz service
Personal Data Encryption
Personal Vault
Privacy resource usage
Privacy transparency and controls
Remote Credential Guard
Remote Wipe
Rust for Windows
Secure Future Initiative (SFI)
Secured kernel
Secured-core PC and Edge Secured-Core
Security baselines
Server Message Block file services
Smart App Control
Smart cards
Software bill of materials (SBOM)
Tamper protection
Token protection (preview)
Transport Layer Security (TLS)
Trusted Boot (Secure Boot + Measured Boot)
Trusted Platform Module (TPM)
Trusted Signing
Universal Print
VBS key protection
Virtual private networks (VPN)
Virtualization-based security enclaves
Web sign-in
Wi-Fi connections

Win32 app isolation
Windows Autopatch
Windows Autopilot
Windows diagnostic data processor configuration
Windows enrollment attestation
Windows Firewall
Windows Hello for Business
Windows Hello
Windows Hotpatch
Windows Insider and Microsoft Bug Bounty Programs
Windows Local Administrator Password Solution (LAPS)
Windows presence sensing
Windows protected print
Windows Sandbox
Windows security policy settings and auditing
Windows Security
Windows Software Development Kit (SDK)
Windows Subsystem for Linux (WSL)
Windows Update for Business